

Functional Specification

Who does what, through which screen or interface, under which rule. Eleven human personas and four system actors, specified as use cases against the build that exists today — not a proposal for one.

DOCUMENT	VERSION	DATE	DERIVED FROM
FSD / Fraud360	1.6	2 October 2026	BRD v1.9 · HLD v1.8
VERIFICATION BASIS	790 automated tests		

HOW THIS DOCUMENT WAS BUILT

Every use case below traces to a business requirement in the BRD and to the running code — the actor's role name, the roles permitted on a state transition, the endpoint a step calls, the status values a record can hold. Where a capability exists only as a roadmap item, the use case says so and is marked **PENDING** rather than described as present. Nothing here is aspirational unless labelled as such.

CONTENTS

1	Purpose, scope & how to read this	13	CRO / ACB / Special Committee
2	System overview	14	Model Risk / Data Science
3	Actors and personas	15	Internal Audit / RBI Inspection
4	Master use-case model	16	Tenant Administrator
5	Cross-cutting specifications	17	Platform Administrator
6	Detection scope — Lane A / Lane B	18	External and system actors
7	Fraud Analyst (L1)	19	Screen & dashboard inventory
8	Senior Investigator (L2)	20	Traceability matrix
9	Fraud Risk Manager	21	Non-functional requirements
10	Principal Officer (PMLA)	22	Key data objects
11	Compliance Supervisor	23	Open items & assumptions
12	Board / Executive	24	AI/ML roadmap

1. Purpose, scope & how to read this

The BRD says what the platform must do and why. The HLD says how it is built. This document says **who** triggers each piece of behaviour, from which screen or interface, in what order, and what the system guarantees them in return.

It is organised by **actor**, not by module, because that is how the people who will sign off on this platform read it: a Principal Officer wants to see everything they can do in one place, not their filing use cases in §9 and their alert use cases scattered through detection. Each of the eleven human personas gets its own section: a one-line summary, a use-case diagram scoped to that actor, a complete table of their use cases, and a small number of fully detailed specifications for the ones that carry the most procedural weight — a natural-justice hearing, a maker-checker fraud declaration, a filing acknowledgement.

Four system actors are specified alongside the human ones — a payment switch or CBS extract job, the bank's identity provider, the regulators who receive a filing, and law enforcement — because a functional specification that only describes what a person can click is missing half of what the platform does. §17 covers them.

NOTATION USED THROUGHOUT

- **UC-XXX-*nn*** — a use-case identifier, prefixed by actor code (see the persona table in §3). Referenced from the traceability matrix in §19 and, where relevant, from other use cases via *includes* — a step that is itself specified in full somewhere else, rather than repeated.
- **BR-*nnn*** — the business requirement in BRD v1.9 that this use case satisfies. A use case with no BR reference is either purely a screen convenience or a system-actor interface documented for completeness.
- **BUILT** / **PARTIAL** / **PENDING** — carried over unchanged from the BRD's own status column. A pending use case is written in the future tense; everything else describes what the running code does today, proven by the test named where it matters.

2. System overview

One paragraph, because the HLD already owns this ground in full.

Fraud360 is a multi-tenant fraud risk management and early-warning-signals platform for Indian banks, co-operative banks and NBFCs. It ingests payments across five rails (UPI, IMPS, NEFT, RTGS, card) and non-payment signals from the core banking system, scores them against each tenant's own board-approved catalogue of indicators, and carries a signal that fires all the way through to a defensible regulatory filing. Two detection lanes exist side by side: an inline lane that returns a go/no-go answer inside the payment window for the rails a tenant configures for it, and a near-real-time lane that scores the full catalogue, including typologies that cannot be known at the moment of authorisation, and raises alerts that a human works. Eleven roles see eleven different slices of the same underlying facts, enforced server-side rather than by hiding a tab in the console.

What follows takes that system as given and asks, screen by screen and interface by interface: who is allowed to do what, and what happens when they do.

3. Actors and personas

Eleven human roles and their access, exactly as the server enforces it — this table is generated from the same role definitions the console asks at login, not maintained separately from them.

PERSONA	UC PREFIX	ROLE KEY	PRIMARY QUESTION	MODULES	SCOPE	UNMASK PII
Fraud Analyst (L1)	ANL	analyst	Which alerts in my queue are real?	Monitoring	Own tenant	Yes, with justification
Senior Investigator (L2)	INV	investigator	Is this one mule, or a ring?	Monitoring	Own tenant	Yes, with justification
Fraud Risk Manager	FRM	risk_manager	Where is the queue failing, and why?	Monitoring, Audit	Own tenant	Yes, with justification
Principal Officer (PMLA)	PO	principal_officer	What must be filed with FIU-IND, by when?	Monitoring, Audit	Own tenant	Yes, with justification
Compliance Supervisor	SUP	supervisor	Are the regulatory clocks being met?	Monitoring, Audit	Own tenant	Yes, with justification
Board / Executive	EXE	board	What is our exposure and are we compliant?	Monitoring	Own tenant	No — aggregate only
CRO / ACB / Special Committee	CRO	cro	Is the framework itself working?	Monitoring, Audit	Own tenant	No — aggregate only
Model Risk / Data Science	MDL	data_scientist	Is the model still fit, fair and explainable?	Monitoring	Own tenant	No — models run on masked data
Internal Audit / RBI Inspection	AUD	rbi_inspector	Can each figure and decision be evidenced?	Monitoring, Audit	Own tenant	Read-only, with justification
Tenant Administrator	TAD	tenant_admin	Is my institution configured correctly?	Control Plane, Monitoring, Audit	Own tenant	Yes, with justification
Platform Administrator (vendor)	PAD	platform_admin	Is the service healthy across tenants?	All four modules	Cross-tenant	No — see below

THE OUTSOURCING BOUNDARY APPLIES TO EVERY USE CASE IN THIS DOCUMENT

No role — including the vendor's own Platform Administrator — can unmask a bank's customer identifiers. This is not a UI restriction; the reveal capability is a field on the role definition itself (`can_reveal_pii`), checked server-side on every field that carries one, and it is `False` for platform staff by design. Where a use case below says "view masked account number", that masking is unconditional for that actor — there is no admin override written into any use case in this document.

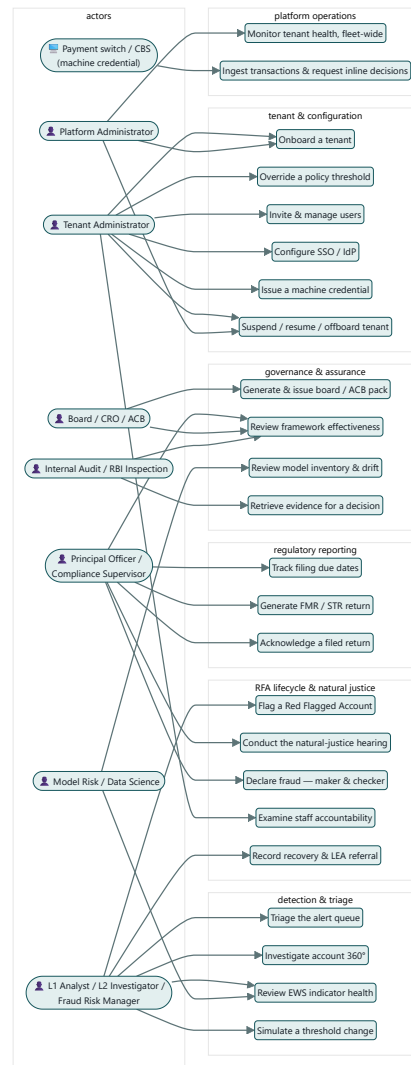
SYSTEM ACTORS, SPECIFIED IN §17

ACTOR	UC PREFIX	RELATIONSHIP
Payment switch / CBS extract / ETL job	EXT	Sends transactions and core-banking events; requests inline decisions. Authenticates as a machine, never as a person
Bank's identity provider	EXT	Authenticates human users via OIDC or SAML 2.0
RBI / NABARD / NHB / FIU-IND	EXT	Receives the generated FMR and STR artefacts
Law enforcement	EXT	Receives a referral recorded against a case

4. Master use-case model

Every capability in the platform, grouped by the question it answers, against the actor groups that use it. Persona-scoped diagrams follow in each of the eleven

sections after this one — this is the map before the detail.



Actor groups on the left stand in for the eleven personas detailed in §6–§16; the payment switch stands in for every machine caller specified in §17. Every use case named here is detailed in its owning persona section, with the endpoint, business rules and BR reference behind it.

5. Cross-cutting specifications

Three use cases sit underneath nearly everything else in this document. Specified once here, and referenced as *includes* from every persona section rather than

repeated eleven times.

UC-AUTH-01 Sign in with a second factor

ACTOR

Every human persona

TRIGGER

The user submits an email and password on the console login screen, or arrives via the bank's SSO link

PRECONDITIONS

The user has an active account for a tenant that is not suspended or offboarded

MAIN FLOW

1. User submits email and password, or is redirected from the bank's OIDC or SAML 2.0 identity provider (discovery is by organisation short name, so the user never has to know which protocol their bank uses)
2. The system verifies the credential and issues an `mfa_pending` token — not a usable session
3. User supplies a TOTP code, or a single-use backup code as fallback
4. The system verifies the code and issues a full session: an access token valid 30 minutes, and a refresh token
5. The refresh token is honoured up to 4 hours of inactivity, or 7 days absolute, whichever comes first

ALTERNATE FLOWS

- **First login** — the user is forced to set a permanent password and enrol a second factor (QR code, confirmed by one live code) before a session is issued. An enrolment that is never confirmed leaves the account without a usable second factor and the login refused, rather than silently weaker
- **Federated sign-on** — the identity provider's signed assertion is read only from the element the signature actually covers (defends against signature wrapping), and the assertion ID is recorded so it cannot be replayed

EXCEPTION FLOWS

- 5 consecutive failures on the password or the TOTP code lock the account for 15 minutes
- A tenant that is suspended or offboarded refuses every login, with the reason — see UC-TEN-01

POSTCONDITIONS

A session exists, scoped to the user's role and tenant; every subsequent action is attributed to it

BUSINESS RULES

BR-706, BR-707, BR-708, BR-709, BR-710

UC-M2M-01 Authenticate a bank system as a machine

ACTOR

Payment switch, CBS extract job, ETL pipeline (system actor, §17)

TRIGGER

The system needs to submit transactions or request an inline decision, and holds no valid token

PRECONDITIONS

A Tenant Administrator has issued a credential scoped `ingest`, `decide`, or both — never full access

MAIN FLOW

1. The system exchanges its client ID and secret for a bearer token via the OAuth2 client-credentials grant — no MFA, and none bypassed, because this credential class has no interactive login path to bypass
2. The token carries the credential's scope and a short expiry
3. Every subsequent call presents the token; the standard principal check refuses machine tokens by default, so an endpoint must opt in to accept one

EXCEPTION FLOWS

- An expired, revoked, IP-disallowed or certificate-mismatched credential is refused with the specific reason, not a generic error
- A token scoped `ingest` cannot request a decision, and vice versa
- The tenant's own lifecycle status is checked on every token issuance and, for the decision path, cached and re-checked every 15 seconds — a suspended tenant's switch stops within that window, not only its human users (see UC-TEN-01)

POSTCONDITIONS

A scoped, time-limited token; every issuance and refusal is audited, since a refusal is often the more interesting record for an investigation

BUSINESS RULES

BR-213

UC-TEN-01 Suspend, resume or offboard a tenant

ACTOR

Platform Administrator (offboarding is a vendor act); Tenant Administrator does not self-suspend

TRIGGER

A commercial or compliance decision to stop, pause, or end service for one tenant

PRECONDITIONS

The tenant is in a state the requested transition permits — **suspend** from active or degraded, **resume** only from suspended, **offboard** from any served state

MAIN FLOW

1. Actor selects the tenant and the transition
2. The system validates the transition against the tenant's current status and applies it
3. Human logins for that tenant are refused immediately with the reason
4. Machine callers stop within the 15-second status cache window on their next token request or decision call
5. The fraud record remains exportable throughout — suspension is not a data lock

POSTCONDITIONS

Tenant status updated; every affected service now refuses that tenant's traffic with a stated reason rather than a generic error

BUSINESS RULES

BR-107

UC-TEN-02 Export a tenant's complete fraud record

ACTOR

Platform Administrator

TRIGGER

A tenant relationship is ending, or a bank exercises its right to its own data under the outsourcing directions

MAIN FLOW

1. Actor requests the export for a tenant
2. The system assembles tenant configuration (branding, thresholds, users) and the fraud record — cases, alerts, the evidence transactions behind them, the transition log including refusals, accountability examinations, LEA referrals, recoveries, and filed FMR/STR returns with their content hashes
3. Full transaction history and document bytes are deliberately excluded from the JSON bundle and instead counted and pointed at the bulk export path — a bundle nobody can open would satisfy the letter of the requirement and fail its purpose
4. The bundle carries an explicit `complete` flag: any section that failed to assemble is named, not silently omitted

POSTCONDITIONS

A bundle the bank can act on independently of the platform, honest about what it does and does not contain

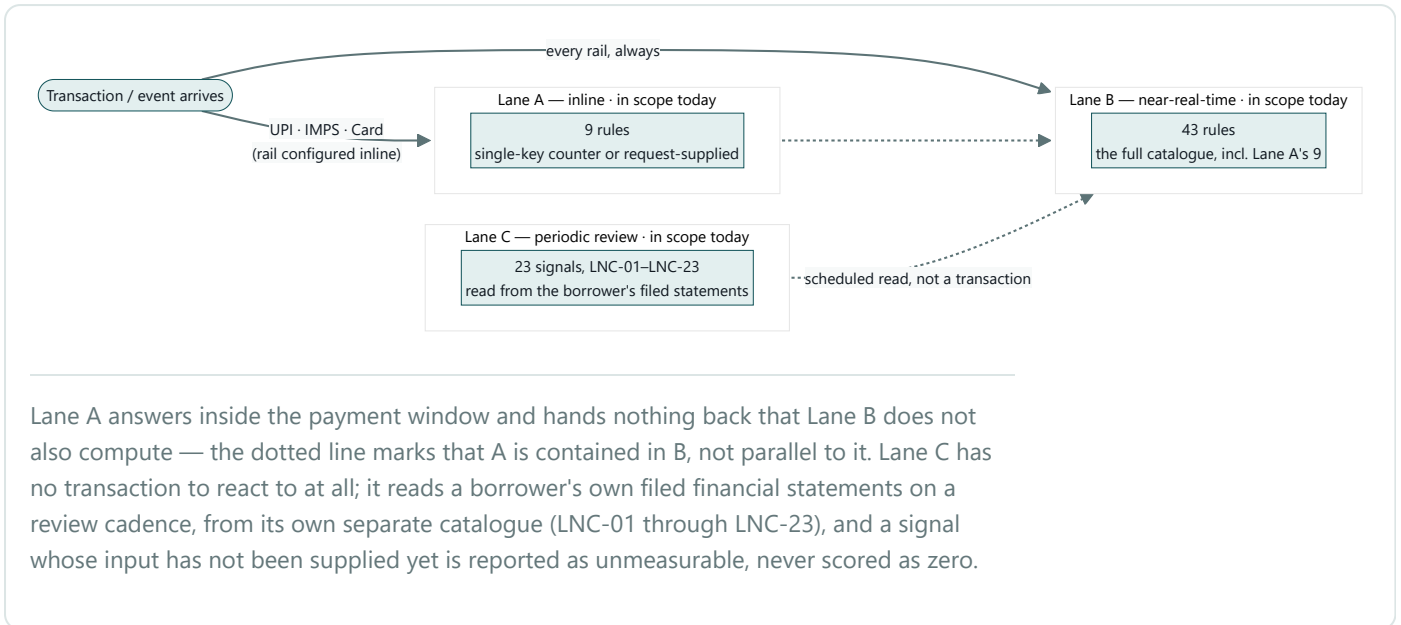
BUSINESS RULES

BR-107, REG-06

6. Detection scope — Lane A / Lane B / Lane C

Which of the 43 EWS rules run where, and why — the question the two-lane architecture raises the moment anyone asks "does real-time mean I lose detection quality?" The answer is a table, not a slogan: Lane A is a strict subset of Lane B, and the boundary is drawn by whether the signal exists yet at the moment of

authorisation, not by how fast a rule happens to compute.



43, 20 AND 9 ARE THE COUNTS FOR A LENDING-CAPABLE ENTITY TYPE — NOT EVERY TENANT (BR-111)

A Payments Bank licence cannot extend credit (RBI/DoS/2026-27/430 carries none of the borrower/financial-performance EWS language every other 2026 Direction does). The 20 rules whose entire premise is a lending relationship — **BEH-02/03** , **CPT-03/04** , **CBS-01/02/03/04/05/06/07/08/09/10** , **QUAL-01/02/03** , **LOS-01/02/03** (BR-214, an application or a valuation cannot exist without a credit facility to originate) — are never seeded for one, not just muted. All 20 are Lane B-only (see the per-rule table below), so Lane A stays at 9 of 9 for every entity type unchanged; only Lane B's count moves, from 43 to 23 for a Payments Bank tenant. Nothing else in the catalogue is gated this way today — see FSD §"Entity-type gating" note under the rule table for what was checked and deliberately left ungated.

Lane A — inline decisioning

Answers **allow** or **decline** (UPI, IMPS) or additionally **challenge** (Card) inside the payment window, on a per-rail latency budget the tenant sets. NEFT and RTGS are routed to Lane B by default — they settle in a window wide enough that scoring with full context finds more than an 80 ms check ever could.

RAIL	DEFAULT MODE	BUDGET	ACTIONS AVAILABLE
UPI	Inline (Lane A)	80 ms	allow, decline
IMPS	Inline (Lane A)	150 ms	allow, decline
Card	Inline (Lane A)	100 ms	allow, challenge, decline
NEFT	Near-real-time (Lane B)	—	—
RTGS	Near-real-time (Lane B)	—	—

UPI and IMPS carry no `challenge` action — the PIN is captured at the remitter's PSP before the request reaches the bank, so by decision time the customer has already authenticated and the only real answers are approve or decline. A rail may not be configured with an action it cannot execute; the platform refuses that configuration outright rather than returning an answer the switch would ignore.

REACHING LANE A OVER ISO 8583, NOT ONLY JSON (BR-317, PARTIAL)

The `/decide` contract above is JSON. Some card/EFT switches have no practical way to originate a JSON call — asking every such vendor to build a translation layer of their own does not scale. A second front door, `iso8583_gateway`, decodes an ISO 8583 authorisation message (the standard public data elements — PAN, amount, transmission time, STAN/RRN, terminal and merchant ids) and calls the same `/decide` contract as any JSON integrator would: same rule catalogue, same policy, same decision log. It is a protocol adapter in front of the one decision engine, not a second one. Core codec, field mapping and connection handling are built and unit-tested; it is not yet deployed for any tenant. Every switch vendor's private data elements and exact response-code table differ, so field mapping is confirmed against a named pilot vendor's own spec before go-live, and whether Fraud360 terminating a raw PAN brings it into PCI-DSS scope is a compliance decision still open. See `docs/ISO8583_LANE_A_SCOPING.md`.

The 36 indicators, by lane

Nine indicators are inline-eligible because their observation is either a precomputed per-account counter or something the channel already supplies with the request — nothing that needs a lookup. All 36 run in Lane B for a lending-capable entity type; the "Lane" column below says which additionally run in Lane A. See the entity-type gating note directly below this table for the one entity type this doesn't hold for.

FAMILY	RULE	LANE	INLINE SOURCE / DEFERRAL REASON
Velocity (VEL)	VEL-01	A + B	Counter — value vs. 30-day baseline
	VEL-02	B only	Same first-seen-pair set as CPT-01, and the same <code>lte</code> trap
	VEL-03	A + B	Counter — rolling small-credit count
Structuring (SME)	SME-01	A + B	Counter — sub-CTR-threshold count
	SME-02	A + B	Counter — near PIN-less UPI limit count
	SME-03	B only	Needs invoice-level data, which no feed supplies
Layering / mule (LAY)	LAY-01	A + B	Counter — outflow vs. inflow ratio
	LAY-02	A + B	Counter — distinct counterparties
	LAY-03	B only	Needs a multi-hop graph traversal; the cycle has not closed yet
	LAY-04	A + B	Counter — accounts sharing the device fingerprint

FAMILY	RULE	LANE	INLINE SOURCE / DEFERRAL REASON
Behavioural (BEH)	BEH-01	A + B	Counter — dormancy gap on a high-value payment
	BEH-02	B only	Needs the CBS repayment funding source, posted after settlement
	BEH-03	B only	Needs end-use tracing across subsequent transactions
Channel / device (CHN)	CHN-01	A + B	Request — new device / new payee / high value, supplied by the channel
	CHN-02	B only	Needs a geolocation feed that is not contracted
	CHN-03	B only	Needs the account's hour profile, held but not published as a counter
Counterparty (CPT)	CPT-01	B only	Beneficiary age needs the first-seen-pair set, not an account counter — an unknown pair would read as age zero and fire on every high-value payment
	CPT-02	B only	Sanctions and PEP screening lists are not loaded in the payment path
	CPT-03	B only	CERSAI charge registry is a lookup, and not on this path
	CPT-04	B only	Title-dispute register is a lookup against the same <code>collateral_ref</code> , and not on this path
Loan conduct (CBS)	CBS-01	B only	Needs the loan account's disbursal-to-withdrawal history from the CBS
	CBS-02	B only	Needs security and stock records from the CBS
	CBS-03	B only	Needs sale-proceeds routing, known only after the fact
	CBS-04	B only	Needs cheque-return events from the CBS (<code>cheque_return</code>); a dishonour never traverses a payment rail
	CBS-05	B only	Needs overdraft/cash-credit drawn-vs-limit positions from the CBS (<code>od_position</code>)
	CBS-06	B only	Needs BG invocation / LC devolvement events from the CBS (<code>bg_lc_event</code>), recorded by the trade-finance desk, not a rail
	CBS-07	B only	Needs fresh facility sanctions flagged as funding interest from the CBS (<code>facility_sanction</code>), a credit-committee fact
	CBS-08	B only	Needs repayment due dates from the CBS (an optional <code>due_date</code> on the existing <code>loan_repayment</code> event); unmeasurable where the extract does not send it
	CBS-09	B only	Needs loan-utilisation events, matched against a verified related-party register not loaded in the payment path
	CBS-10	B only	Same related-party register as CBS-09, narrowed to utilisation also flagged as diverted
Trade-based (TBM)	TBM-01	B only	Needs trade-finance records
	TBM-02	B only	Needs trade-finance records
	TBM-03	B only	Needs the foreign-bills register
Qualitative (QUAL)	QUAL-01	B only	Qualitative, entered by credit monitoring
	QUAL-02	B only	Qualitative, entered by credit monitoring
	QUAL-03	B only	Qualitative, entered by credit monitoring

FAMILY	RULE	LANE	INLINE SOURCE / DEFERRAL REASON
Loan origination (LOS)	LOS-01	B only	Needs the applicant's own account history from the payment stream, plus declared income from the LOS - neither exists at authorisation time
	LOS-02	B only	Needs a peer set of other valuers' assessments, accumulated over up to a year
	LOS-03	B only	Needs a cross-application identity search, not a property of one payment

ENTITY-TYPE GATING (BR-111)

The 20 rules marked "B only" above and named in the table — BEH-02/03 , CPT-03/04 , CBS-01/02/03/04/05/06/07/08/09/10 , QUAL-01/02/03 , LOS-01/02/03 — share one property none of the other 23 do: their premise is a lending relationship (a borrowal account, pledged collateral, a disbursement, a "primary banker", or — for LOS — an application for one). Checked against the actual Chapter III EWS text of all nine RBI 2026 Directions, every entity type carries that borrower/financial-performance language except Payments Bank — a PB licence cannot extend credit, and its Direction (RBI/DoS/2026-27/430) has no credit-related EWS section at all. For a Payments Bank tenant, none of these 20 are seeded at onboarding; the platform starts that tenant on 23 rules, not 43, and detection never evaluates the excluded 20 because they are absent from the tenant's active configuration, not merely deactivated.

TBM-01/02/03 (trade-based: merchanting trade, Letters of Credit, foreign bills) were checked the same way and left ungated on purpose. None of the nine 2026 Directions tie trade-finance authorisation to entity type — that vocabulary traces to RBI's older 2016 EWS circular, not the current Directions — and Authorised Dealer (forex) status is issued to an institution separately from its entity-type licence. Gating TBM by entity_type would encode a guess as if it were a verified fact; it is recorded as a roadmap item pending a per-tenant AD-licence signal the platform does not yet capture, not built now.

Deep dive: The 9 Lane A signals and how they work

Each Lane A rule detects a specific fraud pattern using account counters available at authorization time. Here is what each one catches, in language for a risk conversation.

VEL-01 · VALUE VELOCITY AGAINST BASELINE

What it catches: A single transaction that is dramatically larger than the account's own historical pattern.

Real example: A customer who normally sends ₹5,000–₹15,000 per month suddenly initiates a ₹200,000 transfer. This 13× spike against their 30-day baseline triggers an alert.

How it works: Fraud360 maintains a rolling 30-day average for each account and flags any single payment that exceeds a configurable multiple (often 5–10×). Legitimate spike? The customer can be challenged or the rule threshold adjusted per-tenant. A mule? The pattern fits.

VEL-03 · SMALL-CREDIT FREQUENCY SPIKE

What it catches: A sudden explosion of micro-transactions below a threshold, often used to evade detection or test compromised accounts.

Real example: An account that has never transferred more than twice per day suddenly initiates 15 transfers of ₹9,999 each within a single hour.

How it works: Counts the rolling number of small transfers (below a configurable amount like ₹10,000) in a time window. Structuring fraudsters often use precisely this tactic to stay under AML thresholds while moving large sums.

SME-01 · SUB-CTR STRUCTURING COUNT

What it catches: Multiple transfers just below the Currency Transaction Report (CTR) filing threshold (₹10 lakh), a classic structuring pattern.

Real example: A borrower makes seven separate transfers of ₹9.99 lakh on the same day, totalling ₹69.93 lakh. This is textbook structuring to evade regulatory reporting.

How it works: Counts transactions in a rolling window that fall just below the CTR threshold and flags when the count crosses a limit (typically 3–5 in 24h). The platform knows the exact CTR threshold for your jurisdiction.

SME-02 · PIN-LESS UPI STRUCTURING

What it catches: Rapid-fire micro-UPI transfers (below the PIN-less limit) that collectively move a large amount without individual authentication.

Real example: A compromised phone sends 20 UPI transactions of ₹5,000 each to different beneficiaries within 10 minutes—totalling ₹1 lakh drained from the account without a PIN being entered for each transfer (many banks allow PIN-less UPI up to ₹5,000).

How it works: Tracks the count and volume of UPI transfers below the PIN-less limit in a rolling window. A spike indicates either account compromise or deliberate low-value-transfer fraud.

LAY-01 · OUTFLOW DRAIN (LAYERING)

What it catches: Nearly all money flowing into an account is immediately funnelled out—the hallmark of a money mule or money-laundering layering account.

Real example: An account receives ₹10 lakh over a week and within 3 days sends out ₹9.8 lakh to 12 different beneficiaries. The outflow ratio is 98%—far above the normal 40% for this account type.

How it works: Compares outbound transaction volume to inbound volume in a rolling window (typically 7 days). A ratio above a threshold (often 80–90%) flags the account. Legitimate fast-flowing accounts (traders, e-commerce sellers) can be whitelisted at the tenant's discretion.

LAY-02 · FAN-IN/FAN-OUT HUB (DISTINCT COUNTERPARTIES)

What it catches: An account with an abnormally high number of unique transacting partners—often a sign of a money-collection or distribution hub.

Real example: A new account interacts with 47 different beneficiaries in a single week, whereas the average account at this bank interacts with 3–4. Money is flowing in from some and out to others in rapid succession.

How it works: Counts distinct counterparties (unique beneficiary accounts) in a rolling window and compares to the account's own baseline or a peer baseline. A sudden spike to 40+ unique payees raises an alert. Legitimate high-volume merchants can be configured with higher thresholds.

LAY-04 · DEVICE FINGERPRINT CLUSTERING

What it catches: Multiple accounts being accessed from the same device fingerprint (MAC address, device ID, etc.), suggesting fraud orchestration or account takeover of multiple customer accounts.

Real example: A compromised phone accesses 8 different customer accounts within 30 minutes, each initiating a transfer. The device fingerprint is the same for all 8.

How it works: Maps device fingerprints to account numbers and counts the number of accounts accessed from a single fingerprint. A sharp rise (e.g., from 1 account to 5 accounts) indicates either fraud or a shared-device scenario (family phone). Tenant policy decides the threshold.

BEH-01 · DORMANCY ON LARGE PAYMENT

What it catches: An account that has been inactive suddenly makes a high-value payment—often the account has been dormant for months and an attacker has just compromised it.

Real example: A salaried customer's account has seen no transactions for 8 months, then suddenly initiates a ₹50,000 transfer. The account's baseline suggests this customer is on extended leave or the account is dormant—a sudden large transfer is suspicious.

How it works: Measures the time gap since the account's last transaction and flags if a high-value payment (above a configurable threshold) arrives after an extended dormancy period. Automated reactivation of old accounts often triggers this.

CHN-01 · NEW DEVICE + NEW PAYEE + HIGH VALUE

What it catches: A payment from an unfamiliar device to a unfamiliar beneficiary, in a large amount—the classic account-takeover signature.

Real example: A customer's phone is stolen and used immediately to send ₹30,000 to a new account never seen before. The system sees three red flags at once: device is new, payee is new, amount is high.

How it works: The channel (mobile app or bank branch) supplies this observation directly to Lane A (it's not computed here). The "risk_signals" count combines device newness, payee newness, and value size. A combined score above a threshold (typically 2–3 simultaneous factors) triggers a decline or challenge.

WHY THESE 9 WORK INLINE AND OTHERS DON'T

All nine Lane A rules rely on either (1) precomputed per-account counters that are updated on every transaction, or (2) information the channel already has. No external lookup, no missing data, no waiting for the settlement window. The other 19 rules need either a feed not yet connected (sanctions lists, trade records), a fact that only emerges after settlement (CBS repayment data), or a signal that cannot exist yet (a beneficiary's age, if you have never seen that pair before). Those rules do not belong in a 50–150 ms decision window; they belong in Lane B, where the full account and network context is available.

Deep dive: The 19 Lane B–only signals

These 19 rules run only in Lane B (near-real-time, p99 2.65 seconds after settlement). They either need external data, post-settlement facts, or signals that only form over time.

CPT-01 · BENEFICIARY AGE (NEW PAYEE)

Why it's Lane B only: Requires a set store (first-seen timestamp for each payee pair), not an account counter. If derived from counters alone, an unknown payee would always read as age zero and fire on every large payment—a false positive generator, not a control.

What it catches: Payments to a beneficiary added to the account for the first time, especially in a large amount. Legitimate? Maybe. Suspicious? Depends on the account.

Example: A customer adds a new payee and immediately sends ₹2 lakh. Lane B has the full history and can assess whether the account routinely adds and uses new payees or whether this is out of pattern.

VEL-02 · BENEFICIARY-PAIR AGE VELOCITY

Why it's Lane B only: Same issue as CPT-01—relies on first-seen-pair data that cannot be reconstructed from counters without false alarms.

What it catches: A sudden jump in value to a very new payee pair.

CPT-02 · SANCTIONS / PEP / CENTRAL FRAUD REGISTRY SCREENING

Why it's Lane B only: Sanctions, PEP (Politically Exposed Person) and CFR (BR-509) lists are not loaded in the payment authorization path; they are too large and update too frequently. They are queried asynchronously after settlement.

What it catches: Transactions to or from sanctioned individuals, entities, PEPs without prior disclosures, or parties already reported as fraud elsewhere in the banking system via RBI's Central Fraud Registry.

Example: A payment arrives from an account to an entity later identified as OFAC-listed. The transaction proceeds but an alert is raised in Lane B for investigation and possible reversal.

On CFR specifically: unlike a sanctions list, RBI does not publish CFR as a bulk feed — a bank's users hold individual portal credentials for case-by-case lookups (Directions, Chapter VI-B). The Directions' own definition (para 4(1)) is that CFR is populated *from* a

bank's own FMR filings, not a return the bank files separately — so there is no second filing to build here, only the screening side: a tenant's compliance team loads what its portal lookups found through the same reference-data console every other list uses, honestly unloaded — not silently clean — until they do.

CPT-03 · CERSAI CHARGE REGISTRY

Why it's Lane B only: CERSAI (Central Registry of Securitisation Asset Reconstruction and Security Interest) lookups are external registry calls, not real-time.

What it catches: Transactions from accounts with undisclosed charges, liens, or pledged collateral flagged by CERSAI.

LAY-03 · CIRCULAR/MULTI-HOP MONEY FLOW

Why it's Lane B only: Requires a graph traversal across multiple transactions to detect cycles ($A \rightarrow B \rightarrow C \rightarrow A$). The cycle has not closed at the moment of A's payment; Lane B detects it only after B and C settle.

What it catches: Money laundering "round-tripping" where funds move in circles to obscure origin and create false transaction records.

Example: Funds flow from Account A to B (detected), then B to C, then C back to A. Lane B's post-settlement analysis spots the cycle.

CHN-02 · GEOLOCATION ANOMALY

Why it's Lane B only: Geolocation feeds are not contracted in-path and must be queried post-settlement.

What it catches: A payment from a device whose geolocation is inconsistent with the account's known geography or profile.

Example: An account normally operates in Mumbai but a high-value payment originates from a device located in a high-crime territory or a country on a watch list.

CHN-03 · OFF-HOURS ACTIVITY

Why it's Lane B only: Requires the account's hourly activity profile, which is computed post-settlement and not exposed as a real-time counter.

What it catches: Transactions at hours when the account holder never normally transacts (e.g., 3 AM for an account that always transacts 9–5 AM).

SME-03 · INVOICE-LEVEL TRADE STRUCTURING

Why it's Lane B only: Requires invoice-level data from supply-chain or trade systems— not available at authorization.

What it catches: Over-invoicing or invoice manipulation in trade flows to move money disguised as legitimate commerce.

BEH-02 · REPAYMENT SOURCE MISMATCH

Why it's Lane B only: Requires CBS repayment data, posted after settlement. The repayment funding source is not known until settlement clears.

What it catches: A loan repayment arriving from an unexpected source (not the original borrower, not a known guarantor)—may indicate account takeover or fraud.

Example: A borrower's loan repayment arrives from a third-party account that was never listed as authorized to repay—suspicious and potentially a misapplied payment.

BEH-03 · END-USE DEVIATION

Why it's Lane B only: Requires tracing money across subsequent transactions to confirm it reached its stated end use. Only visible after multiple settlement cycles.

What it catches: Loan funds disbursed for one purpose being diverted to another use—either fraud or violation of loan covenants.

Example: A working-capital loan is disbursed for inventory purchase, but the funds immediately flow into a real-estate investment account. Lane B flags the deviation.

CBS-01 · DISBURSAL-TO-WITHDRAWAL DEVIATION

Why it's Lane B only: Requires loan account history from the CBS (Core Banking System), available post-settlement.

What it catches: A loan disbursed but immediately withdrawn/repaid or moved out before the borrower had time to deploy it—often a sign of layering or loan fraud.

CBS-02 · COLLATERAL AND SECURITY INCONSISTENCY

Why it's Lane B only: Requires stock audit reports and security records from the CBS—not real-time feeds.

What it catches: Transactions from loan accounts where the pledged collateral appears to be missing, sold, or transferred without disclosure.

CBS-03 · SALE PROCEEDS MISROUTING

Why it's Lane B only: Sale proceeds are only known after the asset-sale transaction settles and is recorded in the CBS.

What it catches: Proceeds from an asset sale being routed to unauthorized accounts instead of loan repayment or the borrower's specified account.

TBM-01, TBM-02, TBM-03 · TRADE-BASED MONEY LAUNDERING

Why they're Lane B only: Require trade-finance records (LC details, bills of lading, invoices) and the foreign-bills register—all external to the payment system.

What they catch: Over/under-invoicing, double-invoicing, phantom shipments, and other classic trade-finance fraud schemes.

Example: An import LC shows ₹10 lakh for goods, but the invoice is ₹5 lakh—over-invoicing by 100% to move money across borders in disguise.

QUAL-01, QUAL-02, QUAL-03 · QUALITATIVE CREDIT INDICATORS

Why they're Lane B only: Entered manually by the credit-monitoring team after review of account behavior and external data (media reports, customer complaints, regulatory notices).

What they catch: Red flags identified through human review: adverse media mentions, management concerns, sudden behavioral changes, etc.

Example: The credit team notes that a borrower has appeared in adverse media (alleged involvement in litigation, regulatory penalty, or reputational event). This feeds into the qualitative score in Lane B.

SUMMARY: WHY THE SPLIT WORKS

Lane A (9 rules): Detects the most urgent fraud signatures using only data that exists at authorization time—account counters and channel-supplied signals. Answer in 50–150 milliseconds.

Lane B (43 rules for a lending-capable entity type): Adds 34 more rules that need external feeds, post-settlement facts, or signals that only form after the payment clears — or, for the three loan-origination rules (BR-214), before it. Answer in ~2.65 seconds, but with full context. Includes all of Lane A's signals, so no coverage is lost—only timing. A Payments Bank tenant runs 23 in Lane B, not 43 — the 20 credit-linked rules are never seeded for a licence that cannot extend credit (BR-111, see the entity-type gating note above).

Result: A bank that runs only Lane A gets 9 out of its entity type's catalogue in real time and loses nothing—the 9 catch the highest-confidence attacks and are unaffected by entity-type gating. A bank that runs both gets its full catalogue: 9 at authorization time, the rest after settlement. A bank that runs only Lane B gets the full catalogue but waits 2–3 seconds.

THE BOUNDARY IS NOT SPEED

Three of the thirty-four deferred rules — LAY-03, CPT-01, VEL-02 — are excluded for a reason no amount of engineering removes: the signal has not *formed* yet at authorisation time. A fan-in hub is invisible until the fan has formed; a beneficiary read from a context with no first-seen-pair set would compute as age zero and fire on every high-value payment, which is a broken control, not a fast one. The other thirty-one are deferred because a feed is not yet connected or a fact only exists after settlement — connecting them moves rules from Lane B's "unmeasured" state to scored, not from Lane B to Lane A.

Lane C — periodic borrower assessment BUILT

Lanes A and B both react to a transaction or an account event; nothing in either can read an auditor's qualification or a rise in unbilled revenue, because nothing about those facts arrives on a payment rail. Lane C is a third, deliberately different engine: no transaction stream, a periodic read of the credit file on a review cadence — the way a bank's own credit team already works.

Its catalogue is **LNC-01 through LNC-23** — 23 signals, separate from the payment-rail rule catalogue Lanes A and B share. Between them they answer 23 of the RBI 2016 illustrative early-warning signals, the ones whose underlying fact is about the borrower's filed statements, records or conduct rather than a transaction. How each is measured decides when it can be scored:

- **LNC-01, LNC-03–08, LNC-12–14** — ratios and text patterns read from the borrower's own filed statement, compared with the prior filing. No external dependency.
- **LNC-02** (project scope) and **LNC-22** (project cost variance) — need a project-appraisal baseline and that period's progress submission on file (`POST ... /project-appraisal` , `POST ... /project-progress`); unmeasurable until both exist. LNC-02 also counts how many times the reported completion date has actually changed across every period on file, not just whether the current period's own slip is large — RBI's own word "frequent", answered directly.
- **LNC-09** — a local-LLM read of the statement's notes, off by default; a finding is kept only if its quoted source sentence verifies against the statement text.
- **LNC-10, LNC-17, LNC-18, LNC-19, LNC-20, LNC-23** — one shared reference-feed mechanism (feed kinds `mca_roc` , `insurance_coverage` , `stock_audit` , `shareholding` , `enforcement_action` , `management_changes`); unmeasurable until a tenant configures that feed.
- **LNC-15, LNC-16, LNC-21** — one shared manual-finding mechanism: a credit officer submits a finding for a specific period via the API; unmeasurable until someone does.
- **LNC-11** — a negative rating action. It has no counterpart on RBI's list and is never counted toward the 42; it is added capability, not a checklist item.

An unmeasurable signal is reported as unmeasurable with its reason, never scored as zero.

RBI #	SIGNAL (RBI 2016 ILLUSTRATIVE LIST)	LANE C SIGNAL	COVER	WHAT LANE C READS
1	Default in undisputed payment to statutory bodies per the annual report	LNC-01	Full	Text-pattern read of the notes / auditor's report
3	Frequent change in the scope of the project	LNC-02	Full	Timeline slip against the sanctioned appraisal baseline, AND a count of how many times the completion date has actually changed across every period on file — RBI's own word "frequent", answered directly; needs the appraisal and a progress submission on file
7	Under-insured or over-insured inventory	LNC-17	Full	<code>insurance_coverage</code> reference feed
8	Invoices devoid of TAN and other details	LNC-21	Full	Credit officer's sampled-invoice finding for the period
12	Request to postpone godown inspection for flimsy reasons	LNC-15	Full	Credit / inspection officer's finding for the period
17	Critical issues highlighted in the stock audit report	LNC-18	Full	<code>stock_audit</code> reference feed
18	Liabilities in the ROC search report not reported by the borrower	LNC-10	Full	<code>mca_roc</code> reference feed
25	Non-production of original bills for verification	LNC-16	Full	Credit officer's finding for the period
26	Inventory movements disproportionate to turnover	LNC-03	Full	Ratio vs. the prior filed period

RBI #	SIGNAL (RBI 2016 ILLUSTRATIVE LIST)	LANE C SIGNAL	COVER	WHAT LANE C READS
27	Receivables movements disproportionate to turnover / ageing	LNC-04	Full	Ratio, incl. days-sales-outstanding
28	Disproportionate change in other current assets	LNC-05	Full	Ratio
29	Working capital borrowing rising as a percentage of turnover	LNC-06	Full	Ratio; degrades gracefully when EBITDA is not reported
30	Fixed assets increasing without corresponding long-term sources	LNC-07	Full	Capex vs. new long-term debt / equity raised
31	Borrowings increasing despite large cash balances	LNC-12	Full	Ratio, WC borrowing growth vs. cash-to-revenue
32	Frequent change in accounting period or accounting policies	LNC-08	Full	Fiscal year-end and depreciation-method language, compared across filings
33	Project cost at wide variance with the standard cost	LNC-22	Full	Cost incurred so far vs. the sanctioned appraisal baseline; needs the appraisal and a progress submission on file
34	Claims not acknowledged as debt are high	LNC-13	Full	Contingent liabilities vs. net worth, from a single filing
35	Substantial increase in unbilled revenue year after year	LNC-14	Full	Unbilled-revenue growth vs. turnover
38	Material discrepancies / inconsistencies within the annual report	LNC-09	Partial	Local-LLM read of the statement text, off by default — a probabilistic read, never counted as a full cover
39	Poor disclosure of adverse information, no auditor qualification	LNC-09	Partial	Same LLM read as #38; a finding is kept only if its quoted source sentence verifies against the statement text
40	Raid by Income Tax / GST / TDS / central excise officials	LNC-20	Full	enforcement_action reference feed
41	Reduction in promoter stake or increase in encumbered shares	LNC-19	Full	shareholding reference feed
42	Resignation of key personnel, frequent management change	LNC-23	Full	management_changes reference feed (MCA DIR-12 / KMP filing history)

NONE OF THE 42 IS UNCOVERED — AND THE OTHER 19 ARE NOT LANE C'S

Every one of RBI's 42 illustrative signals now maps to at least a partial indicator: 40 fully covered, 2 partially, 0 not covered. The 23 rows above are Lane C's — 21 fully, 2 partially. The other 19 are answered by the payment-rail and core-banking rules Lanes A and B share — among them cheque returns (CBS-04), BG invocation / LC devolvement (CBS-06), interest funded by a fresh sanction (CBS-07) and delayed repayment (CBS-08), all account events the CBS intake already carries rather than facts a third engine has to read; a verified title-dispute register (CPT-04) and a verified related-party register (CBS-09/10) closed the last three of those this round, replacing the proxies (CPT-03's multiple-charge detection, CBS-01/03's group-exposure ratio) that previously stood in for #9, #16 and #37 — all 19 Lane A/B rows are now full, none by proxy. Stock-audit, ROC/MCA and shareholding data, by contrast, turned out to be periodic facts about the borrower rather than account events, and are read by Lane C through its reference feeds. The only two signals that stay partial are both Lane C's off-by-default local-LLM read (LNC-09, #38/#39) — deliberately never promoted to "full": a probabilistic read should not claim to be deterministic. See `docs/rbi_ews_mapping.py` — the source this table and BRD's own RBI-signal note are both generated from — for the full 42-signal mapping.

7. Fraud Analyst (L1)

PRIMARY QUESTION

Which alerts in my queue are real?

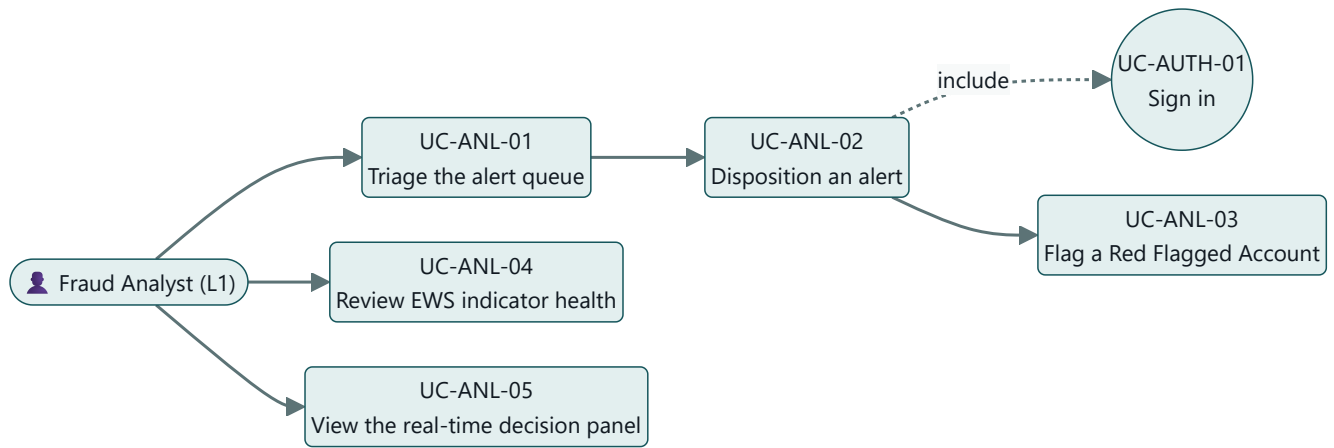
DASHBOARDS

Analyst · EWS Signals · Real-Time

PII

Yes, with justification

The first line. Everything the platform detects arrives here first, and every hour spent chasing a false positive is an hour not spent on a real one — the dormant-indicator register and the reconciliation strip on this screen exist to keep that hour honest.



UC-ANL-02 includes UC-AUTH-01 by definition — every use case in this document assumes an authenticated session, shown explicitly only here as the pattern to read into the rest.

Use cases

ID	NAME	TRIGGER	BRS
UC-ANL-01	Triage the alert queue	Analyst dashboard load, or filter change	BR-603, BR-604, BR-605
UC-ANL-02	Disposition an alert	Analyst opens an alert from the queue	BR-401, BR-402, BR-409, BR-410
UC-ANL-03	Flag a Red Flagged Account	Evidence in the alert supports escalation	BR-401, BR-402, BR-409
UC-ANL-04	Review EWS indicator health	Periodic review, or a dormant-indicator alert	BR-306, BR-307
UC-ANL-05	View the real-time decision panel	Analyst dashboard, Real-Time tab	BR-312, BR-313

UC-ANL-01 Triage the alert queue

ACTOR

Fraud Analyst (L1)

TRIGGER

Analyst opens the console, or changes a filter on an open dashboard

PRECONDITIONS

An authenticated session (UC-AUTH-01); the tenant has at least one active rule catalogue

MAIN FLOW

1. Analyst lands on the Analyst dashboard, scoped by default to their own tenant and the current period
2. The system computes headline KPIs from one shared metric registry and runs reconciliation invariants at query time, shown beside the figures rather than asserted separately
3. Analyst narrows by any of 24 dimensions — rail, family, severity, region, product, segment, and more — and the queue re-sorts
4. Analyst drills from a figure through to the individual transaction and its evidence trail: which rule fired, the observed value, the threshold applied, the configuration version in force at scoring time
5. Analyst distinguishes live traffic from demonstration data on every row — a badge, not an inference

ALTERNATE FLOWS

Analyst saves the current filter combination as a named view for reuse, optionally shared within the tenant and put on a schedule that emails the export to named recipients (BR-609)

POSTCONDITIONS

Analyst holds a prioritised, evidenced queue rather than a raw alert list

BUSINESS RULES

BR-601 to BR-608, BR-611

UC-ANL-02 Disposition an alert

ACTOR

Fraud Analyst (L1); Senior Investigator and Fraud Risk Manager share this use case (UC-INV-02, UC-FRM-03)

TRIGGER

Analyst opens an alert grouped into a case (BR-308 groups related alerts by account, so a mule ring is one investigation)

PRECONDITIONS

The case is in the `under_review` state — the only state this use case's actions apply from

MAIN FLOW

1. Analyst reviews the rule-evaluation trace for every alert on the case
2. Analyst chooses **close — not fraud**, supplying a reason, which moves the case to `exonerated` ; or
3. Analyst chooses **flag as Red Flagged Account** (UC-ANL-03), moving the case to `rfa_flagged` and handing it to Compliance
4. Every attempt — including one an analyst's role is not permitted to take — is written to the case's append-only history, and an unavailable action is shown disabled with the reason rather than hidden

POSTCONDITIONS

The case has moved state, or the analyst has been told exactly why it could not

BUSINESS RULES

BR-401, BR-402, BR-409, BR-410

8. Senior Investigator (L2)

PRIMARY QUESTION

Is this one mule, or a ring?

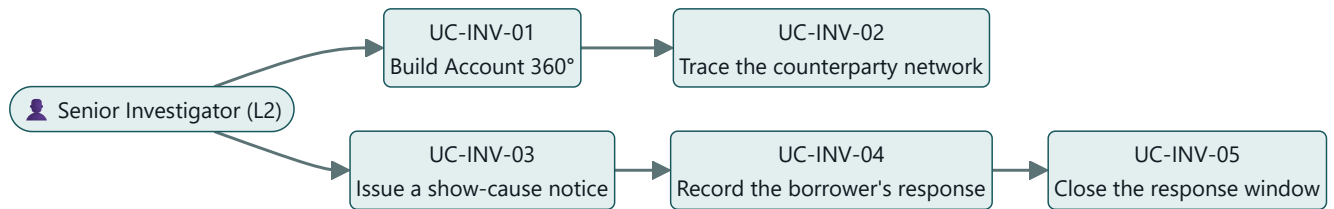
DASHBOARDS

Investigator · Account 360 · RFA Lifecycle · EWS Signals · Analyst

PII

Yes, with justification

Inherits the L1 queue and adds the two things escalation actually needs: a full picture of one account, and the authority to carry a case through the natural-justice hearing that RBI's directions and *SBI v. Rajesh Agarwal* both require before any adverse finding.



UC-INV-03 through UC-INV-05 are three stages of one hearing, specified together below because the guard between them is the whole point of the use case.

Use cases

ID	NAME	TRIGGER	BRS
UC-INV-01	Build Account 360°	Investigator opens an account from a case or a search	BR-603, BR-702, BR-703
UC-INV-02	Trace the counterparty network	Investigator suspects a ring rather than a single actor	BR-310, BR-607
UC-INV-03	Issue a show-cause notice	Case is <code>rfa_flagged</code> and merits a hearing	BR-402, BR-403, BR-408
UC-INV-04	Record the borrower's response	The borrower replies, at any point in the window	BR-405
UC-INV-05	Close the response window	The window has elapsed with no reply	BR-404

UC-INV-01 Build Account 360°

ACTOR

Senior Investigator (L2); also used by Internal Audit / RBI Inspection, read-only (UC-AUD-03)

TRIGGER

Investigator selects an account from a case, an alert, or a direct search

MAIN FLOW

1. The system assembles every fact the platform holds on the account: alert history, case history, transaction evidence, and the graph position (fan-in, fan-out, cluster membership)
2. Customer identifiers are masked by default — account numbers, device IDs, IP addresses
3. Investigator invokes the unmask capability, supplying a justification, which is itself an audited action (viewing is logged, not only changing)
4. Masked or unmasked, the screen is otherwise identical — unmasking changes what is shown, not what is computed

POSTCONDITIONS

Investigator holds a single evidenced view of the account, and the reveal — if any — is on the audit trail

BUSINESS RULES

BR-702, BR-703

UC-INV-03 – UC-INV-05 Conduct the natural-justice hearing

ACTOR

Senior Investigator, Fraud Risk Manager, or Principal Officer — the same three roles the lifecycle grants this transition

TRIGGER

A case is in `rfa_flagged`

PRECONDITIONS

The response-window length is the tenant's own board-approved figure (BR-403) — not a platform constant

MAIN FLOW

1. **Issue show-cause** — moves the case to `natural_justice` and starts the response-window clock. Issuing it after the policy window has already elapsed is permitted and permanently recorded as a breach on the transition, rather than silently allowed or silently blocked
2. **Record the response** — the borrower's reply, whenever it arrives, moves the case to `response_evaluation`. Always permitted; a reply can arrive at any time
3. **Close the window** — with no reply, the case may only move to `response_evaluation` once the window has genuinely elapsed. No user at any seniority may cut it short (REG-02) — the guard is a clock comparison the server evaluates, not a permission a more senior role can override

EXCEPTION FLOWS

An attempt to close the window before it has elapsed is refused with the time remaining, and the refusal itself is written to the case history

POSTCONDITIONS

The case is ready for a decision (UC-FRM-02 / UC-PO-02): declare fraud, or exonerate

BUSINESS RULES

BR-402, BR-403, BR-404, BR-405, BR-408, BR-409

9. Fraud Risk Manager

PRIMARY QUESTION

Are we within SLA and correctly staffed?

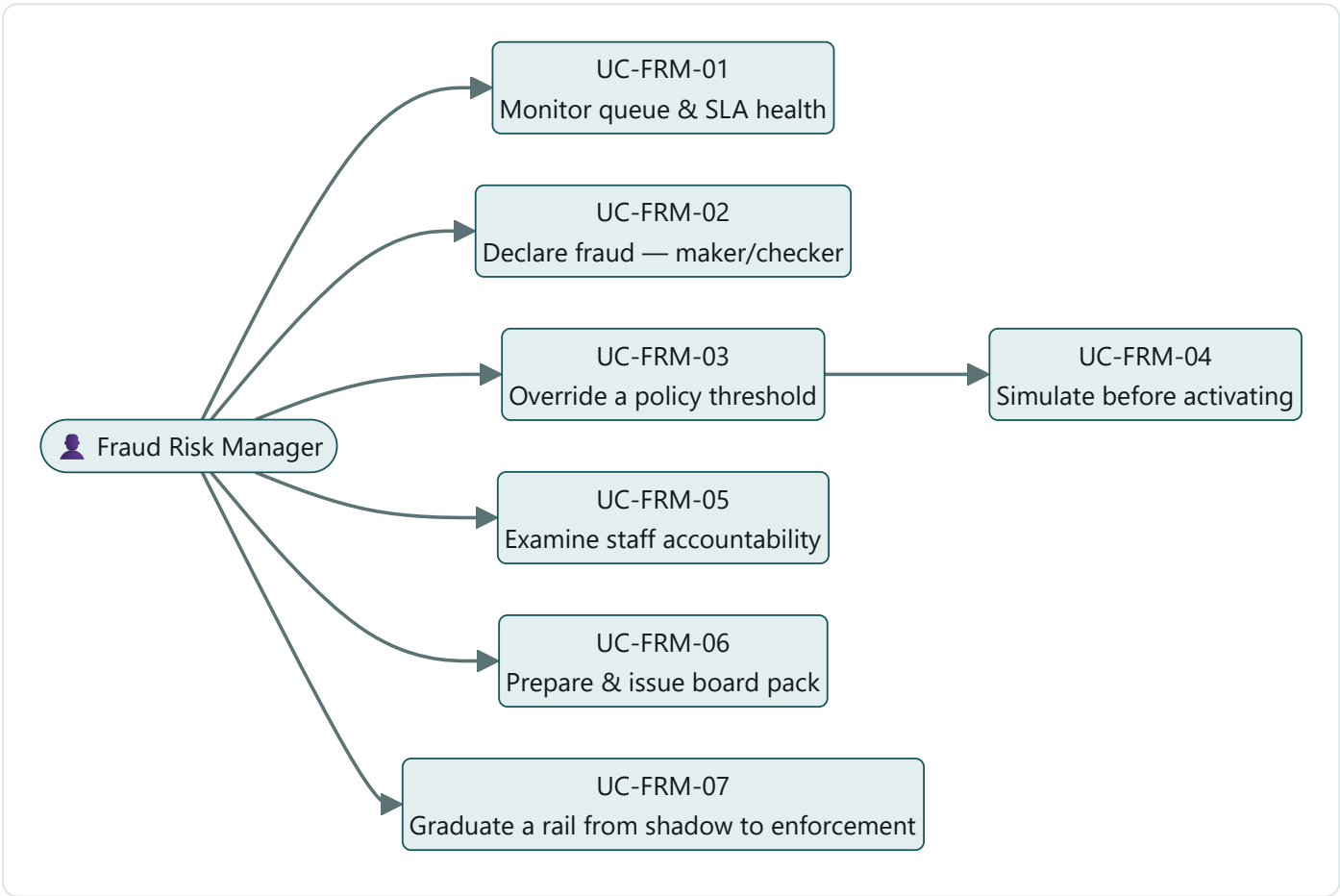
DASHBOARDS

Operations · EWS Signals · Real-Time · Analyst · Investigator · RFA Lifecycle · Board

PII

Yes, with justification

Runs the operation and owns the configuration underneath it — the only persona that both retunes a threshold and answers for the queue that threshold produces.



Use cases

ID	NAME	TRIGGER	BRS
UC-FRM-01	Monitor queue & SLA health	Operations dashboard load	BR-603, BR-208
UC-FRM-02	Declare fraud — maker & checker	Response evaluated, evidence sustains the finding	BR-406, BR-407

ID	NAME	TRIGGER	BRS
UC-FRM-03	Override a policy threshold	A rule is over- or under-firing against real traffic	BR-104, BR-105, BR-106, BR-715
UC-FRM-04	Simulate before activating	Before saving a threshold change	BR-311
UC-FRM-05	Examine staff accountability	A case reaches <code>fraud_declared</code>	BR-414
UC-FRM-06	Prepare & issue board pack	Scheduled cadence, or on demand	BR-507
UC-FRM-07	Graduate a rail from shadow to enforcement	A rail has an observed shadow-mode record and the tenant wants to begin enforcing	BR-313, BR-316

UC-FRM-02 Declare fraud — maker and checker

ACTOR

Fraud Risk Manager, Senior Investigator, or Principal Officer, as maker; a different person holding one of the same three roles, as checker

TRIGGER

Case is in `response_evaluation` and the evidence, including the borrower's reply if any, sustains a finding of fraud

PRECONDITIONS

A `reasoned_order` document is already attached to the case — the speaking order the hearing exists to produce

MAIN FLOW

1. Maker proposes **declare fraud**, supplying a reason; the system refuses the transition outright if no reasoned order is attached (BR-406)
2. The system requires a second, different person holding an approver role to confirm — the proposer can never also be the approver
3. On confirmation, the case moves to `fraud_declared` and three clocks start at once: the FMR filing window, the STR filing window, and the staff accountability examination window

ALTERNATE FLOWS

Exonerate — the same evidence review can instead conclude the allegation is not sustained, moving the case to `exonerated` with a reason and no second approval required

POSTCONDITIONS

A declared fraud with an unforgeable maker/checker record, or an exoneration; either way the case history shows who proposed and who, if anyone, confirmed

BUSINESS RULES

BR-406, BR-407, BR-408, BR-409

ACTOR

Fraud Risk Manager or Tenant Administrator, as proposer; a different person holding Fraud Risk Manager, Tenant Administrator or Platform Administrator, as confirmer

TRIGGER

A rule is producing too many, or too few, alerts against real traffic

MAIN FLOW

1. Actor opens the structured rule editor for the indicator — no hand-edited JSON
2. Actor changes the band, and requests a simulation: the new threshold is run against historical data using the scoring engine itself, not an estimate of it, and the projected alert volume is shown before anything is saved
3. Actor proposes activation of the new version. For a policy config, the system first checks that the activation is board-approved — the approving body, date, and a minute reference. The version now sits as `pending_activation`; nothing scores against it yet (BR-715)
4. A second, different eligible person confirms. Only then is exactly one configuration marked active per (tenant, kind, name), the previous version archived, never deleted, and the tenant's live catalogue updated on the next scoring run, with no deployment. A pending proposal may instead be rejected back to draft by the proposer or another eligible reviewer
5. Every alert scored from this point records the configuration version in force at scoring time (BR-304), so a later question about "what threshold applied then" has a real answer

EXCEPTION FLOWS

Proposing activation of a policy without a recorded approving body is refused (422); confirming with the same account that proposed it is refused (403, self-approval); proposing or confirming from a role outside Fraud Risk Manager / Tenant Administrator / Platform Administrator is refused (403); a config-service outage during activation is a build failure, not a fallback to a lower threshold — see HLD §7 on the fallback-policy incident this guards against

POSTCONDITIONS

One new active version, confirmed by someone other than its proposer; the tenant's entire live catalogue reflects it on the next scoring run, with no deployment

BUSINESS RULES

BR-104, BR-105, BR-106, BR-302, BR-311, BR-715

UC-FRM-07 Graduate a rail from shadow to enforcement

ACTOR

Fraud Risk Manager or Tenant Administrator, as proposer, with Board / ACB sign-off recorded on the record itself; a different person holding Fraud Risk Manager, Tenant Administrator or Platform Administrator, as confirmer

TRIGGER

A rail has run in shadow mode long enough to have an observed false-positive rate, and the tenant wants to begin enforcing it

MAIN FLOW

1. Actor reviews the rail's shadow-mode record (`/decisions/{tenant}/shadow`) — every decision it would have enforced, over the full observation window. Whether each was a genuine catch or a false alarm needs the case disposition, which lives in a different service's schema by design; the false-positive rate is cross-referenced by the actor and recorded, not re-derived by the platform
2. Actor prepares a new `decision_policy` version marking the rail enforced, with a graduation record attached: the observed window (≥ 30 days), the false-positive rate, who evaluated it, and the board/ACB approving body, date and minute reference
3. Actor proposes activation. Both the observation window and the record's completeness are checked before the version may even enter `pending_activation` — a rail marked enforced with no graduation record, or one short of the minimum window, is refused
4. A second, different eligible person confirms (BR-715) — the same maker-checker discipline UC-FRM-03 and UC-MDL-04 already use. Only then does the rail's enforcement status actually change
5. Decision-service picks up the newly active policy off the payment path (the same never-fetch-inline discipline the rule catalogue already has) — a moment of eventual consistency, not a synchronous switch. The graduation record stays on the config version permanently, so a later audit question ("why did we start enforcing this rail, and on what basis") has a real answer

EXCEPTION FLOWS

Proposing activation with an enforced rail carrying no graduation record, or one short of the 30-day minimum, is refused (422, `graduation_required`); confirming with the same account that proposed it is refused (403, `self_approval`). Enforcement never turns on by a missed validation — only by an explicit, recorded decision, confirmed by someone other than who proposed it

POSTCONDITIONS

The rail moves from shadow to enforced; every decision from that point returns its actual action, not always `allow`

BUSINESS RULES

BR-313, BR-316, BR-715

10. Principal Officer (PMLA)

PRIMARY QUESTION

What must be filed with FIU-IND, and by when?

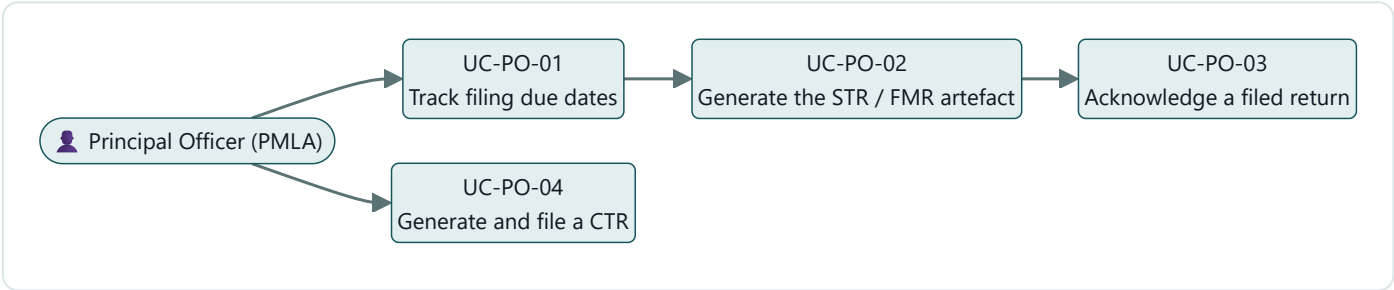
DASHBOARDS

AML / STR · RFA Lifecycle · Compliance

PII

Yes, with justification

The PMLA obligation runs on its own track, independent of whether a case is also travelling the fraud-classification lifecycle — an STR can be filed on a case that never becomes a declared fraud, which is why this persona's dashboard and clocks are separate from the RFA lifecycle's.



Use cases

ID	NAME	TRIGGER	BRS
UC-PO-01	Track filing due dates	AML / STR dashboard load	BR-501, BR-503
UC-PO-02	Generate the STR / FMR artefact	Case reaches <code>fraud_declared</code> , or an STR trigger independent of it	BR-502, BR-504, BR-505
UC-PO-03	Acknowledge a filed return	The regulator's acknowledgement is received	BR-506
UC-PO-04	Generate and file a CTR	An account's cash transactions for the calendar month reach the PMLA Rule 3 threshold	BR-508

UC-PO-02 Generate the FMR / STR artefact

ACTOR

Principal Officer, Compliance Supervisor, Fraud Risk Manager, or Tenant Administrator — the server checks role membership in this list, or the caller's `can_admin_tenant` capability, so a Platform Administrator also has access without being named explicitly

TRIGGER

A case's FMR or STR clock is running and the underlying evidence is complete

PRECONDITIONS

The case carries an FMR category classification (BR-502) and, for FMR, a reasoned order. For STR, the filing Principal Officer's name must be set on the tenant's active, attested FRM policy, which a tenant admin now sets from the console; see §23

MAIN FLOW

1. Actor requests generation for the case and the filing kind
2. The system assembles the return from the case, its evidence and the reasoned order; validates it against the schema; computes a content hash; and retains it with the generation timestamp and the data version behind it
3. A prior `generated` filing for the same case and kind is marked `superseded` rather than overwritten
4. The system refuses to generate a return with a known evidentiary gap, rather than producing an incomplete filing that reads as ready

EXCEPTION FLOWS

Format binding. The return is assembled, validated, hashed and retained in the platform's own structured form. The prescribed RBI / FIU-IND submission format itself is `not_bound` pending OD-04 — the published schemas have not been adopted. A named officer can submit from the pack today; the platform cannot yet claim the artefact is in the regulator's own file format **PARTIAL**

POSTCONDITIONS

A retained, hashed filing record, ready for submission and for UC-PO-03

BUSINESS RULES

BR-501, BR-502, BR-504, BR-505, BR-506

UC-PO-04 Generate and file a Cash Transaction Report

ACTOR

Principal Officer, Compliance Supervisor, Fraud Risk Manager, or Tenant Administrator — same role set as UC-PO-02, since a CTR pack carries the same class of account identifiers

TRIGGER

An account's cash transactions for a calendar month — deposits and withdrawals both, individually or in aggregate — reach the Rs 10,00,000 threshold under PMLA Rule 3

PRECONDITIONS

At least one `cash_transaction` CBS event has been reported for the account in the period, explicitly marked live — see Exception flows

MAIN FLOW

1. Actor checks the due list for a calendar month: every account whose reported cash transactions already meet the threshold
2. Actor requests generation for one account and period. The system aggregates every `cash_transaction` event for that account in that calendar month, computes the total, and assembles the return
3. A prior `generated` filing for the same account and period is marked `superseded` rather than overwritten, exactly as UC-PO-02
4. The system refuses to generate a return for an account that has not actually met the threshold that month, rather than producing one nobody was required to file

EXCEPTION FLOWS

Provenance. A CTR may not be built from anything other than cash-transaction events explicitly marked live — the CBS event pipeline has fed only detection indicators until now, where scoring demonstration data is normal, so nothing before this needed a live/synthetic distinction on that stream. This is the first CBS-derived *filing*, so it is the first consumer to require one (BR-611).

Format binding. Same honesty as UC-PO-02: the FIU-IND FINnet CTR schema itself is `not_bound` — nothing has examined it yet **PARTIAL**

POSTCONDITIONS

A retained, hashed filing record for one account and one calendar month, ready for submission — structurally independent of the FMR/STR filing table, since a CTR is not about a case

BUSINESS RULES

BR-508, BR-611

11. Compliance Supervisor

PRIMARY QUESTION

Are the regulatory clocks being met?

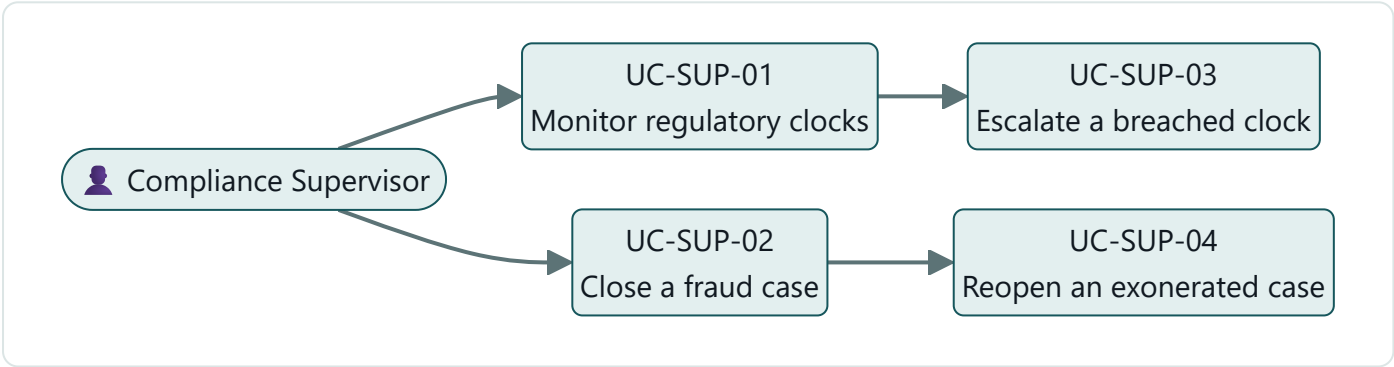
DASHBOARDS

Compliance · RFA Lifecycle · AML / STR · EWS Signals · Board

PII

Yes, with justification

Sits above the case-by-case work, watching the clocks rather than any one case — the 30-day EWS examination window the Master Directions set (2024 originals, superseded 31 Jul 2026 by nine entity-specific successors — see BRD REG-01), and the filing and hearing windows the tenant's own policy sets.



Use cases

ID	NAME	TRIGGER	BRS
UC-SUP-01	Monitor regulatory clocks	Compliance dashboard load	BR-503
UC-SUP-02	Close a fraud case	Case is <code>fmr_reported</code>	BR-414
UC-SUP-03	Escalate a breached clock	A clock approaches or breaches its window	BR-413
UC-SUP-04	Reopen an exonerated case	New evidence surfaces after exoneration	BR-401

UC-SUP-02 Close a fraud case

ACTOR

Compliance Supervisor, or Fraud Risk Manager

TRIGGER

Case is in `fmr_reported` and the supervisor considers the record complete

PRECONDITIONS

The staff accountability examination opened on this case has reached `concluded`

MAIN FLOW

1. Supervisor requests **close case**
2. The system checks the accountability guard: a fraud may be *reported* to RBI with the examination still open, because reporting must not wait on it, but it may not be *closed away* with the question never answered
3. On a concluded examination, the case moves to `closed_fraud` — a terminal state; it cannot be reopened, because it has already been reported

EXCEPTION FLOWS

Closure with an open or absent examination is refused, naming which case blocks it — precisely the paper-compliance gap an inspection looks for

POSTCONDITIONS

The case is closed and immutable; only `exonerated` cases, not `closed_fraud` ones, may ever be reopened (UC-SUP-04)

BUSINESS RULES

BR-401, BR-414

12. Board / Executive

PRIMARY QUESTION

What is our fraud exposure and trend?

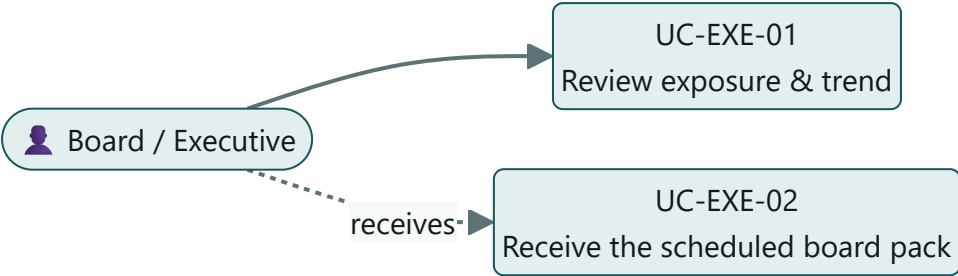
DASHBOARDS

Board

PII

No — aggregate only

One dashboard, deliberately. Everything this persona sees is aggregate by construction — the role carries no PII-reveal capability, so there is no screen to restrict; the figures shown are already the only figures the role can ever see.



UC-EXE-02 is dashed because the Board persona is the pack's *recipient*, not its preparer — UC-FRM-06 in §8 does the preparing and issuing.

UC-EXE-01 Review exposure and trend
ACTOR
Board / Executive
TRIGGER
Board dashboard load, or the delivered board pack
MAIN FLOW
1. The system presents fraud value, case counts, RFA and closure trend, and compliance posture, built from the same metric registry every other dashboard reads — the board sees a different aggregation of the identical figures the analyst sees at transaction level, never a separately computed one 2. Every figure carries its reconciliation status alongside it, at query time
POSTCONDITIONS
A governance-grade view with no customer-identifying detail anywhere on the screen, by construction rather than by a filter a mistake could remove
BUSINESS RULES
BR-601, BR-602, BR-603

13. CRO / ACB / Special Committee

PRIMARY QUESTION

Is the framework itself working?

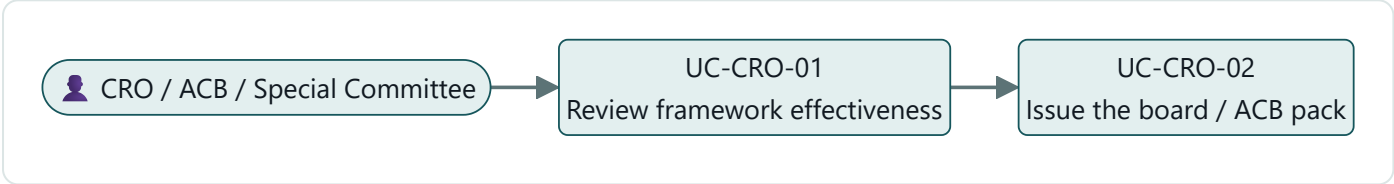
DASHBOARDS

Board · Compliance · RFA Lifecycle · Operations · AML / STR · EWS Signals

PII

No — aggregate only

Governance needs exposure and compliance posture together, not one or the other — the only persona spanning the Board's aggregate view and the Compliance Supervisor's clock view, still with no PII-reveal capability across either.



UC-CRO-02 Issue the board / ACB pack

ACTOR

CRO / ACB / Special Committee, or Fraud Risk Manager, Principal Officer, Tenant Administrator (preparation only — see UC-FRM-06)

TRIGGER

The scheduled cadence for the tenant's pack has arrived, or the committee requests one on demand

MAIN FLOW

1. A pack is **prepared** for the period that has actually finished — never the period the committee is still sitting in, which would show an incomplete figure as though it were final
2. The pack is a frozen record: content-hashed, versioned, and an unissued draft for the same period is superseded by a later preparation rather than edited in place
3. The CRO, or another issue-permitted role, **issues** the pack — a deliberate, separate act from preparing it. An issued pack is never superseded; the committee has seen it and the minutes refer to it
4. Delivery to named recipients is recorded per recipient, so "was this actually sent" has an answer independent of "was it prepared"

POSTCONDITIONS

An immutable, delivered pack the committee's minutes can cite by hash

BUSINESS RULES

BR-507

14. Model Risk / Data Science

PRIMARY QUESTION

Is detection still fit for the population?

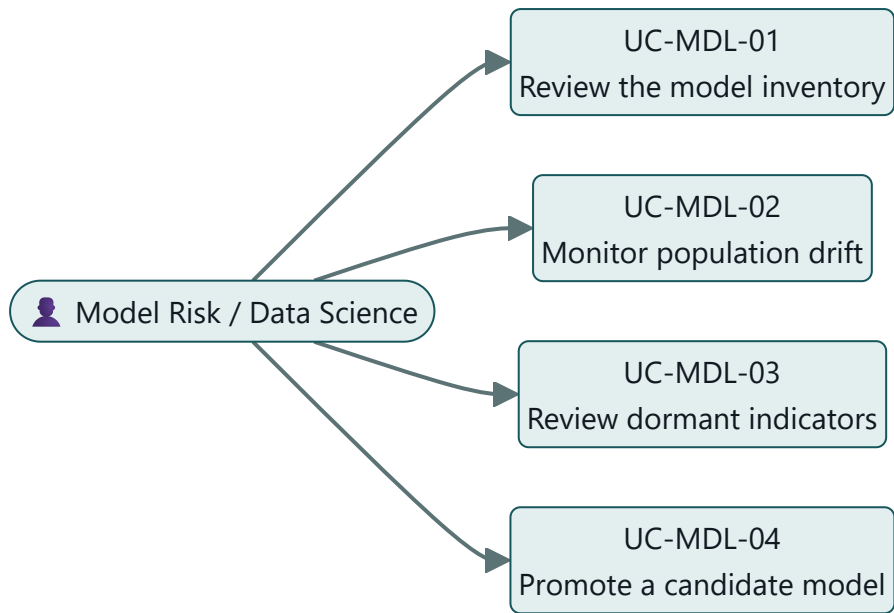
DASHBOARDS

Model Risk · EWS Signals · Analyst

PII

No — models run on masked data

The one persona defined by what it must *not* see rather than what it must: FREE-AI model governance requires detection work to run on masked data, so this role carries no reveal capability under any circumstance — not "usually masked", never unmasked.



Use cases

ID	NAME	TRIGGER	BRS
UC-MDL-01	Review the model inventory	Model Risk dashboard load	BR-801, BR-802
UC-MDL-02	Monitor population drift	Periodic review, or a drift alert	BR-803
UC-MDL-03	Review dormant indicators	Periodic review of the EWS dashboard	BR-307
UC-MDL-04	Promote a candidate model	A candidate model version has been evaluated and is proposed for activation	BR-807, BR-808, BR-715

UC-MDL-02 Monitor population drift**ACTOR**

Model Risk / Data Science

TRIGGER

Periodic review, or an inventory entry flagged as scoring live traffic under a configuration that is not currently approved

MAIN FLOW

1. The system computes Population Stability Index and Kolmogorov–Smirnov statistics between a reference window and the current one, banded into a plain-language read rather than a raw statistic alone
2. The system attributes drift to specific rules — PSI says the population shifted; the per-rule breakdown says where to look
3. Every alert remains explainable to a non-technical reviewer without reference to source code — the same rule-evaluation trace an analyst reads

POSTCONDITIONS

A drift reading the reviewer can act on — retune, backtest, or escalate to champion/challenger evaluation (UC-MDL-04)

BUSINESS RULES

BR-801, BR-803, BR-805

UC-MDL-04 Promote a candidate model

ACTOR

Model Risk / Data Science, as proposer; a different person holding Model Risk / Data Science, Fraud Risk Manager, Tenant Administrator or Platform Administrator, as confirmer

TRIGGER

A candidate model version has been backtested (BR-806) against the version it would replace and is ready to be proposed for activation

MAIN FLOW

1. Actor records the champion/challenger evaluation on the candidate's `model` config version: what was measured, the method, and how it compares to the champion it would replace — or, for a tenant's first model, that there was no champion to compare against
2. Actor records the Model Risk Management Committee's approval: approving body, date, and a minute reference — the same mechanism BR-104 uses for a board-approved policy, naming a model-specific committee
3. Actor proposes activation. Both records are checked before the version may even enter `pending_activation` — a blank evaluation or attestation is refused, not defaulted
4. A second, different eligible person confirms (BR-715). Only then is the version marked active and the previous one archived, never deleted

EXCEPTION FLOWS

Proposing activation without a recorded evaluation is refused (422, `challenger_evaluation_required`); without a recorded committee approval, refused (422, `attestation_required`); confirming with the same account that proposed it is refused (403, `self_approval`)

POSTCONDITIONS

One new active model version, with its evaluation and committee approval attached to the row and its confirmer distinct from its proposer. No live scoring reads this version yet — Fraud360 has no ML detection in production (see [AI/ML roadmap](#), OD-06); this is the gate a model needs before it can be promoted, built ahead of one existing

BUSINESS RULES

BR-807, BR-808, BR-715, BR-104

15. Internal Audit / RBI Inspection

PRIMARY QUESTION

Can each figure and decision be evidenced?

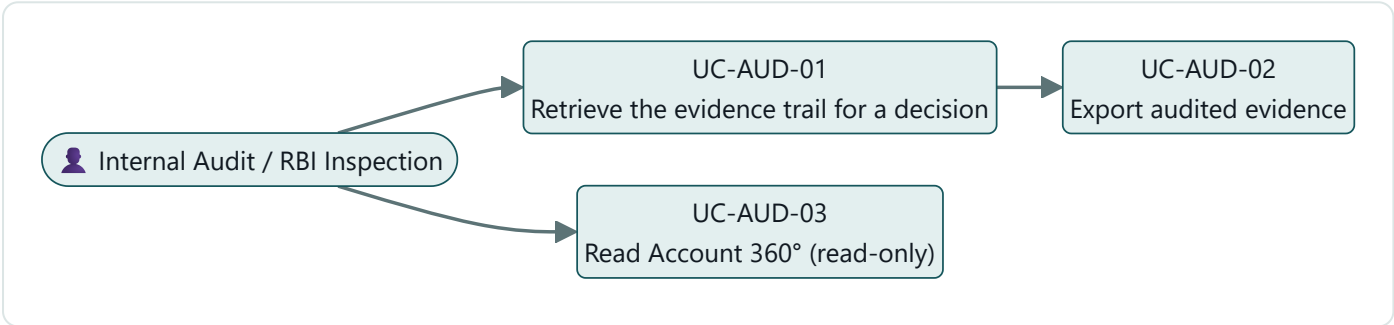
DASHBOARDS

Inspection · RFA Lifecycle · Compliance · Board · AML / STR · Model Risk · EWS Signals · Account 360

PII

Read-only, with justification

Sees more of the platform than any tenant-scoped role except the Tenant Administrator, and changes none of it — enforced by holding no admin capability and no Control Plane module access at all, not by convention.



UC-AUD-01 Retrieve the evidence trail for a decision

ACTOR

Internal Audit / RBI Inspection

TRIGGER

An inspection question: why was this account flagged, why was this fraud declared, why was this threshold changed

MAIN FLOW

1. Auditor opens the Inspection dashboard and locates the case, alert, or configuration change in question
2. The system shows the rule-evaluation trace behind an alert (which band matched, the observed value, the threshold, the configuration version), the full case transition history including every refused attempt, and — for a threshold change — the approving body, date and minute reference recorded at activation
3. Unmasking a customer identifier along the way is available, and is itself audited as a view, not only as a change
4. The auditor's own access is unable to alter anything on the screens it reads — no admin capability is granted to this role under any configuration

POSTCONDITIONS

A defensible answer to "why", backed by a record the auditor did not have to trust the platform's word for — every figure traces to a stored trace, not a derived narrative

BUSINESS RULES

BR-304, BR-409, BR-606, BR-703, BR-705

16. Tenant Administrator

PRIMARY QUESTION

Is my institution configured correctly?

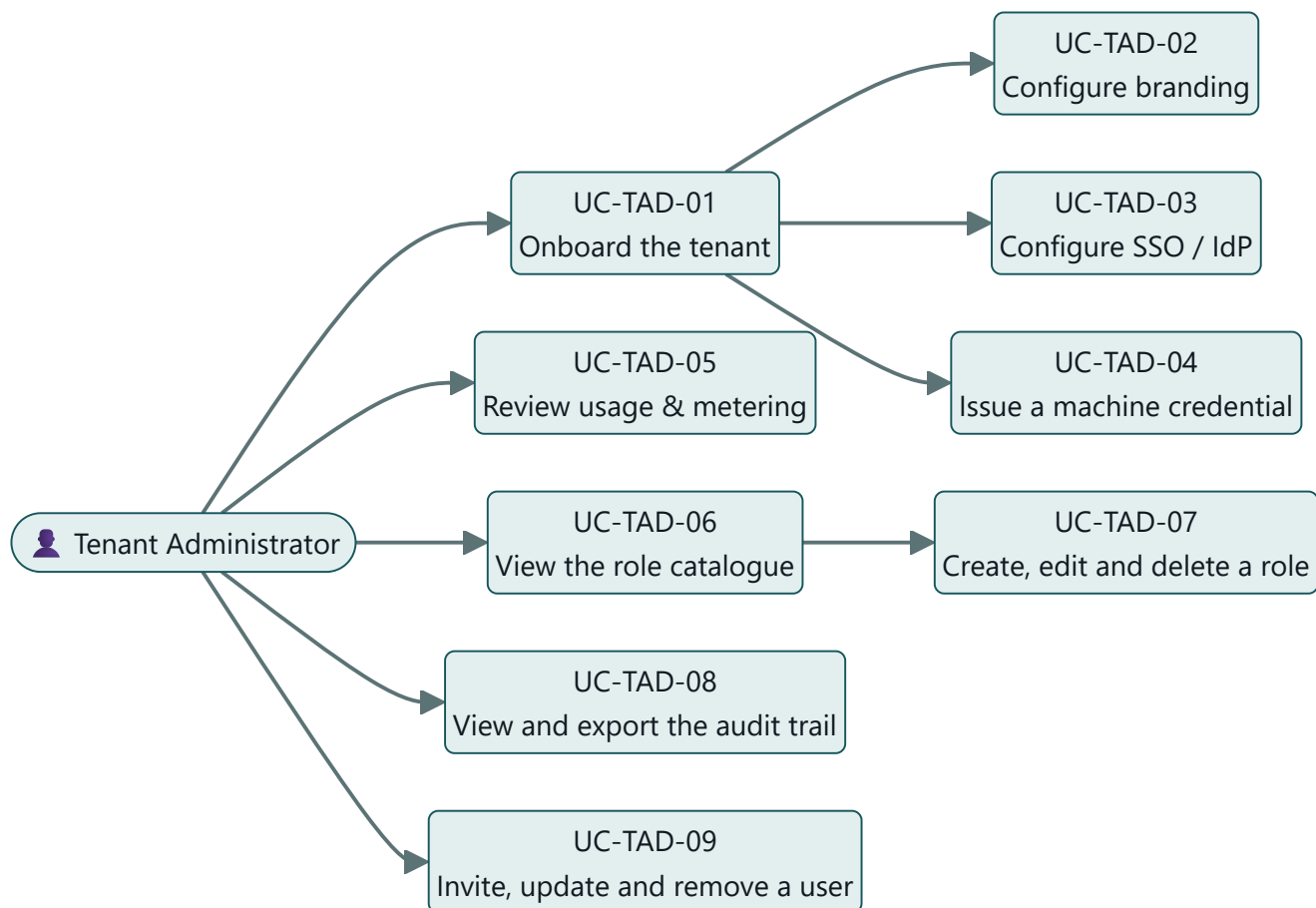
MODULES

Control Plane · Monitoring · Audit

PII

Yes, with justification

The bank's own break-glass role: every dashboard a tenant-scoped persona can see, plus the configuration surface underneath the whole platform for that one institution. `tenant_admin` is added automatically to every case transition's permitted-roles list in the lifecycle engine (§8, HLD), so this persona can always act when no one else can.



Use cases

ID	NAME	TRIGGER	BRS
UC-TAD-01	Onboard the tenant	Platform Administrator provisions a new institution (UC-PAD-01), handed to the tenant's first administrator	BR-101, BR-103
UC-TAD-02	Configure branding	Onboarding, or a rebrand	BR-102
UC-TAD-03	Configure SSO / IdP	The tenant wants federated sign-on against its own directory	BR-708
UC-TAD-04	Issue a machine credential	A payment switch, CBS extract job, or ETL pipeline needs to connect	BR-213
UC-TAD-05	Review usage & metering	Billing period close, or on demand	BR-110
UC-TAD-06	View the role catalogue	Deciding which role to assign a new user, or auditing who holds an admin-capable or PII-revealing role	BR-112, BR-113
UC-TAD-07	Create, edit and delete a role	The fixed ten roles do not match the bank's own org structure	BR-113
UC-TAD-08	View and export the audit trail	Reviewing recent activity, or assembling evidence for a compliance review or an RBI inspection request	BR-701, BR-705, BR-716

ID	NAME	TRIGGER	BRS
UC-TAD-09	Invite, update and remove a user	Staff joins, changes desk, or leaves — without waiting on the vendor's own platform staff to act on the tenant's behalf	BR-108

UC-TAD-06 View the role catalogue
ACTOR
Tenant Administrator (any tenant-scoped role, in fact — see below)
TRIGGER
Deciding which of the ten roles to invite a new user under, or checking who in the bank currently holds an admin-capable or PII-revealing role
MAIN FLOW
1. Actor requests <code>GET /tenants/{id}/roles</code> 2. The system returns every role this tenant has — the fixed ten, plus any it has created itself (UC-TAD-07) — never <code>platform_admin</code>, which is cross-tenant and excluded here the same way BR-108's invite flow already excludes it from what a tenant may hand out. Each entry carries its label, the modules and dashboards it reaches, whether it can administer the tenant, whether it can reveal customer PII, whether an elevation is pending confirmation, and how many of this tenant's own users currently hold it 3. The system reads this tenant's own materialised <code>tenant_roles</code> rows if BR-113 (phase 2a) has seeded them — every tenant onboarded from that point on — and falls back to the platform's hardcoded catalogue otherwise. The two sources are verified indistinguishable to the caller: the same response shape, checked against the same test suite either way
POSTCONDITIONS
Nothing changes — this is read-only. Creating, editing, deleting or assigning a role happens through UC-TAD-07 and BR-108's invite flow, not here
BUSINESS RULES
BR-112, BR-113

UC-TAD-07 Create, edit and delete a role

ACTOR

Any role holding `can_admin_tenant` — checked dynamically, so a custom role the tenant has granted admin scope to can manage further roles itself, not only the seeded `tenant_admin`

TRIGGER

The fixed ten roles do not match the bank's own org structure — a title, a narrower grant, or a role scoped to one region or desk

MAIN FLOW

1. Actor names a role, chooses its modules and dashboards, and optionally grants any combination of `can_admin_tenant`, `can_reveal_pii` and `can_activate_config` (the risk_manager-equivalent capability to propose or confirm a configuration activation, BR-715 — independent of admin scope), via `POST /tenants/{id}/roles`
2. The system refuses a name that collides with one of the platform's ten reserved names (including `platform_admin`), and refuses any grant reaching the platform-only `administration` module or the `tenant_health` dashboard — regardless of who is asking. Cross-tenant reach needs no separate check: the tenant a role belongs to is always the URL path, never a field the caller controls
3. A grant that does not raise any of the three capability flags applies immediately on `PUT /tenants/{id}/roles/{name}` — this includes lowering any of them, which is always safe to apply unilaterally. Editing a seeded role marks it `custom`: it is no longer an unedited copy of the platform catalogue
4. A grant that *raises* any of the three is staged, not applied, and needs a different eligible actor to confirm it via `POST /tenants/{id}/roles/{name}/confirm` — the same maker-checker asymmetry BR-715 applies elsewhere. The actor who staged it cannot confirm their own change (`self_approval`, refused)
5. The system deletes a custom role via `DELETE ... /roles/{name}`, refusing one of the fixed ten outright and refusing any role still held by a user until they are reassigned
6. The resulting role becomes immediately assignable through BR-108's existing invite flow — a custom role is not a second-class name; the moment it exists, `POST /tenants/{id}/users` accepts it exactly as it would `analyst` or `risk_manager`

EXCEPTION FLOWS

`reserved_name` / `name_exists` (422) — the name collides with a platform role or an existing one of the tenant's own. `role_guardrail` (422) — the grant reaches platform-only surface. `insufficient_role` (403) — the caller lacks `can_admin_tenant`, dynamically checked. `self_approval` (403) — the proposer tried to confirm their own elevation. `fixed_role` / `role_in_use` (409) — delete refused. Every refusal is audited, not only every success

POSTCONDITIONS

Every create, edit, confirmation and delete — success or refusal — writes a full before/after snapshot to the audit trail, so a role's history is reconstructable without a separate version table and is never rewritten in place

BUSINESS RULES

BR-113'S CAPABILITY CHECK NOW RUNS PLATFORM-WIDE, THREE FLAGS DEEP

A tenant's roles are real, editable, per-tenant database rows — the write path, the platform-only guardrails, the maker-checker elevation and the full audit snapshot on every change are all built (phase 2b). A custom role is functional within tenant-service's own admin surface, assignable to a user via BR-108, and — phase 2c — recognised by analytics-service, config-service, decision-service and notification-service too, through `cp_common.dynamic_roles` : a shared module every one of them imports, fetching a tenant's custom-role catalogue from tenant-service's `GET /tenants/internal/{tenant_id}/roles` and caching it against the same generation-token mechanism config-service's rule/policy changes already use, so an edit is visible everywhere the instant it is made, not after some clock interval. Every one of the ten fixed roles still resolves with zero network calls — nothing about existing behaviour changed for them. `ingestion-service` needed no change at all: BR-213 machine credentials carry scopes, not human roles.

Phase 2d closed the sharpest remaining gap: config-service's

`maker_checker.ELIGIBLE_ROLES` used to be a hardcoded name list mixing `risk_manager` in alongside the two admin-capable roles, because `TenantRole` had no flag for "may activate configuration" on its own. It has one now — `can_activate_config` , checked dynamically the same way as the other two — so `ensure_eligible()` is one capability check instead of a name comparison plus a fallback, and a custom role can be granted exactly the `risk_manager`-equivalent capability, independent of `can_admin_tenant` . Raising it is staged through the same elevation confirmation as the other two flags; a bank does not get to hand out configuration authority any more casually than it hands out admin scope. What remains open is narrower still: a small number of call sites (analytics-service's `FILING_ROLES / CTR_ROLES`) mix in roles like `principal_officer` that no flag on this platform describes at all — extending those means new capability flags, real and separately-scoped, not attempted here. Recorded rather than left implicit, in the same spirit as the BR-108 invite-flow finding above.

UC-TAD-08 View and export the audit trail

ACTOR

Any role granted the `audit` module — `tenant_admin`, `risk_manager`, `principal_officer`, `supervisor`, `cro`, `rbi_inspector` by default, or a BR-113 custom role granted it explicitly

TRIGGER

Reviewing recent activity in the console's Audit panel, or assembling evidence for a compliance review or an RBI inspection request

MAIN FLOW

1. Actor requests `GET /audit`, optionally with `action_prefix` (e.g. `role.` for role-management events only) — the console's "Role changes only" checkbox sets this
2. The system scopes the result to the caller's own tenant automatically; platform staff may target any tenant, or omit one for the fleet-wide view
3. Actor downloads the same, filtered trail as CSV via `GET /audit/export` — the console's Download CSV button — for a record that survives outside the console

EXCEPTION FLOWS

`insufficient_role` (403) — the caller's role, fixed or custom, does not grant the `audit` module. `cross_tenant` / 403 — a tenant-scoped caller requested a `tenant_id` other than their own

POSTCONDITIONS

Nothing changes — this is read-only, the same as UC-TAD-06

BUSINESS RULES

BR-701, BR-705, BR-716

FOUND WHILE ANSWERING "IS AUDIT ACCESS ACTUALLY IN PLACE": IT WAS GRANTED, NOT ENFORCED

`cp_common.rbac` has granted the `audit` module to six tenant-scoped roles since long before this session, and the console has shown all six an "Audit" nav item for just as long. `GET /audit`, however, was gated `require_role("platform_admin")` — so every one of those six roles 403'd the instant they used the feature the platform's own `rbac.py` said they had. A specification or a test written against the same assumption the code made would not have caught this; it surfaced only by checking the grant against the actual route guard. Fixed under BR-701/BR-716: the endpoint now checks audit-module access dynamically (fixed or BR-113 custom role), pinned to the caller's own tenant. Verified against the running console, including a role created and exercised live through the UI, not only by unit test.

DELIBERATELY NOT ADMIN-GATED, AND NOT THE SAME AS `/AUTH/ME`

`/auth/me` already tells a signed-in user their *own* modules and dashboards, for console navigation. UC-TAD-06 is different: it is the full catalogue side by side — every role, what each can reach, and this tenant's actual headcount against each one — which nothing exposed before BR-112. It carries the same access level as `GET /tenants/{id}/users`, which it complements: any authenticated user of the tenant, not only an administrator. That is a deliberate match to an existing precedent, not a new, looser boundary — this endpoint changes no privilege, it only reports one that already governs every other route.

UC-TAD-02 Configure branding

ACTOR

Tenant Administrator

MAIN FLOW

1. Actor sets display name, logo, primary/accent/neutral colours, default theme and (where applicable) a custom domain for their own tenant only
2. The system serves the resulting theme as CSS and JSON, cached by clients — branding is treated as non-sensitive and requires no authentication to fetch

POSTCONDITIONS

The console renders under the tenant's own identity from the next page load

BUSINESS RULES

BR-102

UC-TAD-04 Issue a machine credential

ACTOR

Tenant Administrator

TRIGGER

A bank system needs to submit transactions or request inline decisions without a human logging in

MAIN FLOW

1. Actor names the credential, selects a scope — `ingest` , `decide` , or both, never full access — and optionally an IP allow-list and a certificate binding
2. The system generates a client ID and secret; the secret is shown exactly once and is never retrievable afterwards
3. Actor may later **rotate** the credential (issuing a new secret with an overlap window so rotation is not an outage) or **revoke** it outright, with a reason recorded

POSTCONDITIONS

A scoped, attributable credential the bank's own systems use instead of a shared user password with MFA disabled

BUSINESS RULES

BR-213

UC-TAD-09 Invite, update and remove a user

ACTOR

Any role granted `can_admin_tenant` — `tenant_admin` by default, dynamically checked so a BR-113 custom role granted it works identically

TRIGGER

Staff joins, changes desk, or leaves

MAIN FLOW

1. **Invite** — `POST /tenants/{id}/users` with an email and any role this tenant actually has (the ten fixed roles, or a custom one); a one-time temporary password is returned and never logged
2. **Update** — `PUT /tenants/{id}/users/{id}` reassigns role. For a local-password user this is the only way to change a role at all; for an SSO-federated user it is a stopgap between logins — the directory re-syncs the role automatically on their next sign-in regardless (UC-TAD-03; `routes/sso.py::_complete_sso`), so this does not compete with that sync, it only covers the gap before it next runs
3. **Remove** — `DELETE /tenants/{id}/users/{id}`
4. Every one of the three is refused if it would leave the tenant with nobody able to administer it — not merely if it would leave zero users. Removing the tenant's fourth user out of five is refused if that fourth user is the only one left with `can_admin_tenant`, even though three other people would still have accounts

EXCEPTION FLOWS

`insufficient_role` (403) — caller lacks `can_admin_tenant`. `unknown_role` (422) — the role named does not exist for this tenant. `last_user` (409) — would leave the tenant with zero accounts. `last_admin` (409) — would leave the tenant with accounts but no one able to administer them

POSTCONDITIONS

Every invite, update and removal is audited with a full record — for update, the role it changed from and to

BUSINESS RULES

BR-108

FOUND AND FIXED: INVITE AND REMOVE WERE PLATFORM-STAFF-ONLY, AND UPDATE DID NOT EXIST

The persona table (§3) and BR-108 both described a tenant administrator inviting their own users. As implemented until this session, `POST /tenants/{id}/users` and `DELETE ... /users/{id}` were both `require_role("platform_admin")` — only the vendor's own staff could act, not the tenant's own administrator, and there was no way to change an existing user's role at all, by any actor. All three are now UC-TAD-09, gated by the same dynamic `can_admin_tenant` check BR-113 already uses, with a sole-admin safety net strengthened at the same time — the previous check only refused emptying a tenant to zero users, not to zero **administerable** users, which this wider actor set made a real risk rather than a theoretical one.

17. Platform Administrator

PRIMARY QUESTION

Is the service healthy across tenants?

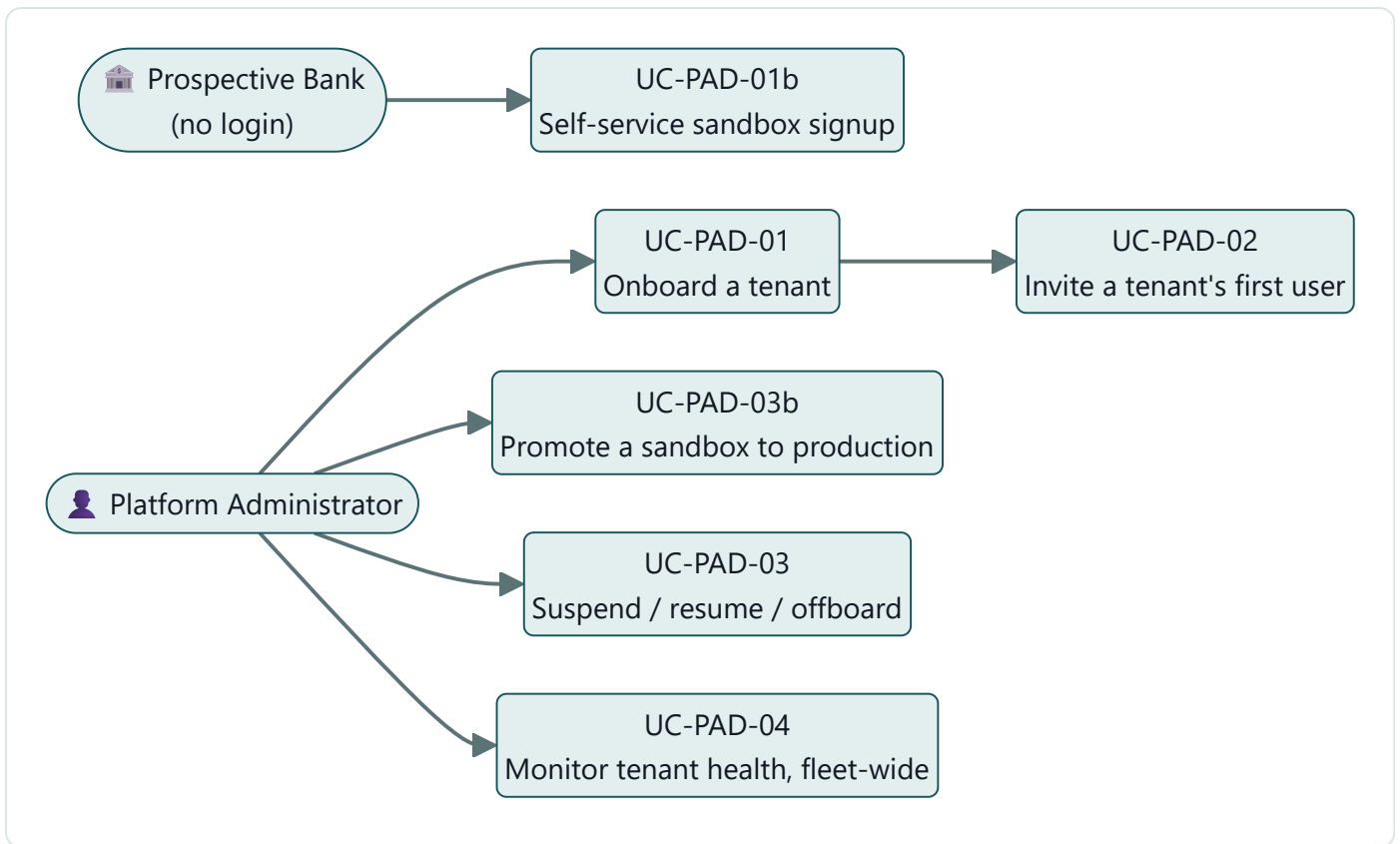
MODULES

Control Plane · Monitoring · Audit · Administration (all four)

PII

No — see the outsourcing boundary in §3

The vendor's own role. The only persona not scoped to one tenant, and — deliberately — the only one whose breadth is not matched by a PII-reveal capability: operating the service does not require seeing a bank's customers, and that is the first question an outsourcing review asks.



Use cases

ID	NAME	TRIGGER	BRS
UC-PAD-01	Onboard a tenant	A new institution signs a contract	BR-101, BR-103
UC-PAD-01b	Self-service sandbox signup	A prospective bank wants to integrate before any contract is signed	BR-109
UC-PAD-02	Invite a tenant's first user	Immediately after onboarding	BR-108
UC-PAD-03	Suspend / resume / offboard	Contractual or compliance decision — includes UC-TEN-01, UC-TEN-02	BR-107
UC-PAD-03b	Promote a sandbox to production	Commercial agreement reached with a sandbox's owning bank	BR-109
UC-PAD-04	Monitor tenant health, fleet-wide	Operational monitoring, incident response	BR-208, BR-902, BR-905

UC-PAD-01 Onboard a tenant

ACTOR

Platform Administrator

MAIN FLOW

1. Actor registers the entity: slug, legal name, entity type, and — for co-operative banks — supervisory tier
2. The system derives the tenant's default FRM policy from entity type and tier, including the governing Direction and the correct reporting line (RBI, NABARD, NHB, or FIU-IND) — a UCB and a commercial bank do not inherit the same starting policy
3. The system seeds the tenant's starter EWS rule catalogue, gated by what its entity type is licensed to do — a Payments Bank does not receive the 20 credit-linked rules a lending entity type does, because it cannot generate the underlying event (BR-111)
4. The tenant enters `provisioning`, then `active`, ready for UC-PAD-02 and UC-TAD-01

POSTCONDITIONS

A tenant with its own configuration, isolated by database role from every other tenant on the platform

BUSINESS RULES

BR-101, BR-103, BR-111. This is the `platform_admin` path; a prospective bank may instead self-provision a sandbox with no `platform_admin` involved at all — see UC-PAD-01b (BR-109)

UC-PAD-01b Self-service sandbox signup

ACTOR

Prospective Bank (unauthenticated — no platform_admin, no prior tenant, no login of any kind)

TRIGGER

A bank's own integration team wants a working environment to build and test against before a commercial relationship exists

MAIN FLOW

1. Actor reaches `POST /tenants/self-service` — the one path the gateway admits under the `tenants` segment with no bearer token — either directly, or through the "Request a free sandbox" form on the console's own login page
2. Actor submits the same fields UC-PAD-01 collects (slug, legal name, display name, entity type) plus their own admin email and a password of their choosing
3. Refused if the slug is taken (`slug_conflict`), or if this email already administers another live sandbox (`sandbox_exists` — one self-service sandbox per email, so a script cannot spin up an unbounded number)
4. The system runs the identical onboarding orchestration UC-PAD-01 does — default FRM policy, starter EWS catalogue, branding — but the resulting tenant carries `is_sandbox = true`
5. Actor signs in immediately with the email and password just chosen; no invitation, no waiting on a platform_admin

POSTCONDITIONS

A fully functional tenant, reachable on every real endpoint, that can never submit a batch labelled `source="live"` — `/ingest/{tenant_id}/transactions` and `/cbs-events` both refuse it outright (`sandbox_cannot_be_live`) for as long as `is_sandbox` stays true. Isolation is enforced at the endpoint, not left to the integrator's own honesty about labelling

BUSINESS RULES

BR-109 **BUILT**

UC-PAD-04 Monitor tenant health, fleet-wide

ACTOR

Platform Administrator

TRIGGER

Routine operational monitoring, or an incident

MAIN FLOW

1. The Tenant Health dashboard — excluded from every tenant-scoped role, including Tenant Administrator, since a bank's own admin has no business in another bank's operational telemetry — shows ingestion lag, feed freshness and queue depth across every served tenant
2. Actor identifies a degraded pipeline before a bank's own analysts notice the gap

POSTCONDITIONS

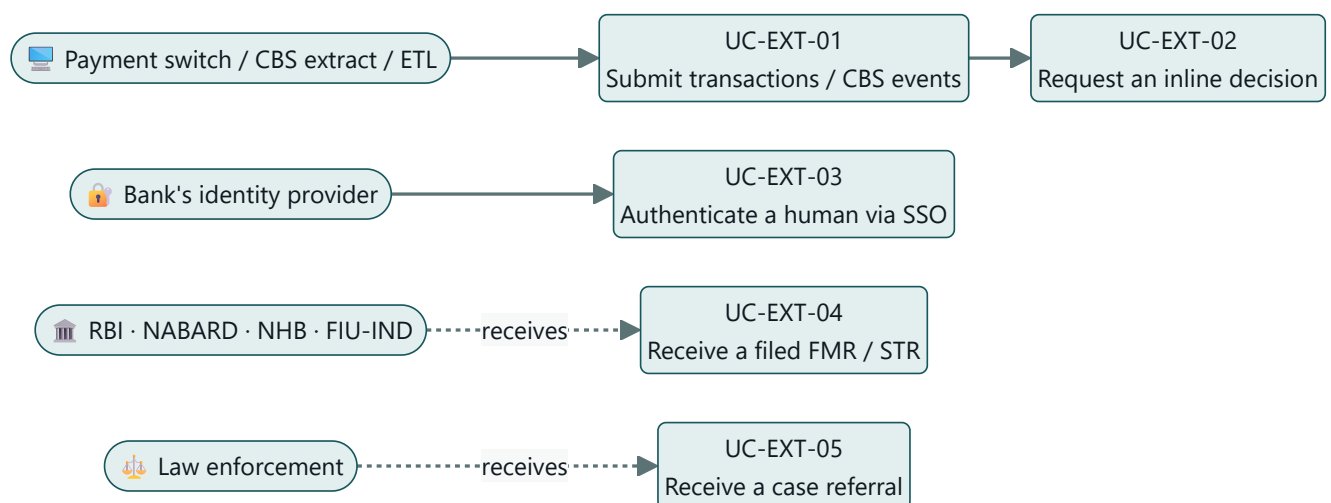
An operational issue is caught at the platform level, scoped to no single tenant's customer data

BUSINESS RULES

BR-208, BR-902, BR-903, BR-905

18. External and system actors

Nothing above reaches the platform without one of these four. They are specified with the same rigour as the human personas, because a machine caller can do more damage per minute than any of them.



UC-EXT-01 Submit transactions or core-banking events

ACTOR

Payment switch, CBS extract job, or ETL pipeline, authenticated per UC-M2M-01

MAIN FLOW

1. Caller submits a batch over REST (JSON), or a bulk file over SFTP in CSV or ISO 20022 `pacs.008` / `pain.001`
2. Every rail's native shape is mapped to one canonical transaction at the edge, so no detection rule ever learns what a UPI collect request looks like versus an RTGS credit
3. Money is represented as integer paise throughout; an amount finer than one paisa is rejected rather than rounded, and a timestamp without a timezone offset is rejected with an explanatory error
4. The system deduplicates on the rail's own identifier, so a replayed file does not double-count value
5. A batch is accepted *partially*: each rejected row is reported with its index and reason, and the rest are retained — the caller learns exactly which three of forty thousand rows failed, not that the whole file did
6. The inbound payload is retained immutably, separate from anything derived from it, with the time of receipt — so "we sent you 40,000 rows and you booked 39,997" is answerable with the three rows, not a count

POSTCONDITIONS

Accepted rows enter the near-real-time detection lane; queue depth, provenance and freshness are exposed for operational monitoring (UC-PAD-04)

BUSINESS RULES

BR-201 to BR-212

UC-EXT-02 Request an inline decision

ACTOR

Payment switch, for a rail the tenant has configured into the inline lane

TRIGGER

A UPI, IMPS or card payment is at the point of authorisation

MAIN FLOW

1. Switch calls the decision endpoint with the payment and whatever signals the channel already knows — new device, new beneficiary
2. The system evaluates the rail's inline-eligible rule subset against a per-rail latency budget (50–150 ms, set by the tenant) and returns allow, challenge, hold, or decline
3. A rail configured for the near-real-time lane instead is refused with `rail_not_inline` rather than answered `allow` — an unscreened rail must never look screened
4. If the budget expires mid-evaluation, the response names which rules did not run and the outcome is recorded as `budget_exceeded`, never as a clean pass
5. While a rail is in shadow mode, the response the switch acts on is always `allow`; the decision the platform would have enforced is recorded separately for UC-FRM-01's operations view

POSTCONDITIONS

A decision returned inside the payment window, fully explained in the same terms an alert is explained

BUSINESS RULES

BR-312, BR-313, BR-314, BR-315

Remaining system-actor use cases

ID	NAME	NOTES
UC-EXT-03	Authenticate a human via SSO	See UC-AUTH-01. Discovery by organisation short name; the signed assertion is read only from the element the signature covers, and assertion IDs are recorded to refuse replay
UC-EXT-04	Receive a filed FMR / STR	The output of UC-PO-02 / UC-PO-03. Prescribed submission format binding is PARTIAL , pending OD-04
UC-EXT-05	Receive a case referral	Recorded against a case alongside any recovery entries (BR-415); transmission to the agency is outside the platform's boundary

19. Screen & dashboard inventory

Thirteen dashboards inside the Monitoring module, each answering one persona's stated question — this table is the same one the console asks the server for at login, not a separately maintained description of it.

DASHBOARD KEY	LABEL	PRIMARY PERSONA	QUESTION IT ANSWERS
analyst	Analyst	L1 Fraud Analyst	What do I work next, and is it real?
ews	EWS Signals	Fraud Risk Manager / Analyst	Which indicators are firing — and which are silent?
rfa	RFA Lifecycle	Investigator / Compliance	Where is each red-flagged account in its lifecycle?
board	Board	CRO / ACB / Special Committee	What is our exposure and are we compliant?
supervisor	Compliance	Compliance Supervisor	Are the regulatory clocks being met?
realtime	Real-Time	Operations	What is flowing right now, and what are we stopping?
aml	AML / STR	Principal Officer (PMLA)	What must be filed with FIU-IND, by when?
account360	Account 360	Investigator	Everything known about one account
investigator	Investigator	L2 Senior Investigator	Is this one mule, or a ring?
model	Model Risk	Model Risk / Data Science	Is the model still fit, fair and explainable?
tenant_health	Tenant Health	Platform Administrator	Which bank's pipeline is degraded?
risk_manager	Operations	Fraud Risk Manager	Where is the queue failing, and why?
inspection	Inspection	Internal Audit / RBI Inspection	Prove why this account was flagged

Which of these thirteen a given persona sees is exactly the "Dashboards" row in that persona's summary card in §6–§16 — `tenant_health` is the one dashboard excluded from every tenant-scoped role, including Tenant Administrator, since a bank's own admin has no business in another bank's operational telemetry.

20. Traceability matrix

Every use case specified in this document, the business requirements it satisfies, and the honest status of each — generated from the same requirement-status data the BRD itself carries, so this table cannot silently drift from it.

UC ID	NAME	PERSONA	BR REFERENCES	STATUS
UC-AUTH-01	Sign in with a second factor	Cross-cutting	BR-706, BR-707, BR-708, BR-709, BR-710	BUILT
UC-M2M-01	Authenticate a bank system as a machine	Cross-cutting	BR-213	BUILT
UC-TEN-01	Suspend, resume or offboard a tenant	Cross-cutting	BR-107	BUILT

UC ID	NAME	PERSONA	BR REFERENCES	STATUS
UC-TEN-02	Export a tenant's complete fraud record	Cross-cutting	BR-107	BUILT
UC-ANL-01	Triage the alert queue	Fraud Analyst (L1)	BR-601, BR-602, BR-603, BR-604, BR-605, BR-606, BR-607, BR-608, BR-609, BR-611	BUILT
UC-ANL-02	Disposition an alert	Fraud Analyst (L1)	BR-401, BR-402, BR-409, BR-410	BUILT
UC-ANL-03	Flag a Red Flagged Account	Fraud Analyst (L1)	BR-401, BR-402, BR-409	BUILT
UC-ANL-04	Review EWS indicator health	Fraud Analyst (L1)	BR-306, BR-307	BUILT
UC-ANL-05	View the real-time decision panel	Fraud Analyst (L1)	BR-312, BR-313	BUILT
UC-INV-01	Build Account 360°	Senior Investigator (L2)	BR-702, BR-703	BUILT
UC-INV-02	Trace the counterparty network	Senior Investigator (L2)	BR-310, BR-607	BUILT
UC-INV-03	Issue a show-cause notice	Senior Investigator (L2)	BR-402, BR-403, BR-408	BUILT
UC-INV-04	Record the borrower's response	Senior Investigator (L2)	BR-405	BUILT
UC-INV-05	Close the response window	Senior Investigator (L2)	BR-404	BUILT
UC-FRM-01	Monitor queue & SLA health	Fraud Risk Manager	BR-603, BR-208	BUILT
UC-FRM-02	Declare fraud — maker & checker	Fraud Risk Manager	BR-406, BR-407, BR-408, BR-409	BUILT
UC-FRM-03	Override a policy threshold	Fraud Risk Manager	BR-104, BR-105, BR-106, BR-715	BUILT
UC-FRM-04	Simulate before activating	Fraud Risk Manager	BR-311	BUILT
UC-FRM-05	Examine staff accountability	Fraud Risk Manager	BR-414	BUILT
UC-FRM-06	Prepare & issue board pack	Fraud Risk Manager	BR-507	BUILT
UC-FRM-07	Graduate a rail from shadow to enforcement	Fraud Risk Manager	BR-313, BR-316	BUILT
UC-PO-01	Track filing due dates	Principal Officer (PMLA)	BR-501, BR-503	BUILT
UC-PO-02	Generate the STR / FMR artefact	Principal Officer (PMLA)	BR-502, BR-504, BR-505	PARTIAL

UC ID	NAME	PERSONA	BR REFERENCES	STATUS
UC-PO-03	Acknowledge a filed return	Principal Officer (PMLA)	BR-506	BUILT
UC-PO-04	Generate and file a CTR	Principal Officer (PMLA)	BR-508, BR-611	BUILT
UC-SUP-01	Monitor regulatory clocks	Compliance Supervisor	BR-503	BUILT
UC-SUP-02	Close a fraud case	Compliance Supervisor	BR-401, BR-414	BUILT
UC-SUP-03	Escalate a breached clock	Compliance Supervisor	BR-413	BUILT
UC-SUP-04	Reopen an exonerated case	Compliance Supervisor	BR-401	BUILT
UC-EXE-01	Review exposure & trend	Board / Executive	BR-601, BR-602, BR-603	BUILT
UC-EXE-02	Receive the scheduled board pack	Board / Executive	BR-507	BUILT
UC-CRO-01	Review framework effectiveness	CRO / ACB	BR-603, BR-503	BUILT
UC-CRO-02	Issue the board / ACB pack	CRO / ACB	BR-507	BUILT
UC-MDL-01	Review the model inventory	Model Risk / DS	BR-801, BR-802	BUILT
UC-MDL-02	Monitor population drift	Model Risk / DS	BR-801, BR-803, BR-805	BUILT
UC-MDL-03	Review dormant indicators	Model Risk / DS	BR-307	BUILT
UC-MDL-04	Promote a candidate model	Model Risk / DS	BR-807, BR-808, BR-715	BUILT
UC-AUD-01	Retrieve evidence trail for a decision	Internal Audit / RBI Inspection	BR-304, BR-409, BR-606, BR-703, BR-705	BUILT
UC-AUD-02	Export audited evidence	Internal Audit / RBI Inspection	BR-610	BUILT
UC-AUD-03	Read Account 360° (read-only)	Internal Audit / RBI Inspection	BR-702, BR-703	BUILT
UC-TAD-01	Onboard the tenant	Tenant Administrator	BR-101, BR-103	BUILT
UC-TAD-02	Configure branding	Tenant Administrator	BR-102	BUILT
UC-TAD-03	Configure SSO / IdP	Tenant Administrator	BR-708	BUILT
UC-TAD-04	Issue a machine credential	Tenant Administrator	BR-213	BUILT
UC-TAD-05	Review usage & metering	Tenant Administrator	BR-110	BUILT

UC ID	NAME	PERSONA	BR REFERENCES	STATUS
UC-TAD-06	View the role catalogue	Tenant Administrator	BR-112, BR-113	BUILT
UC-TAD-07	Create, edit and delete a role	Tenant Administrator	BR-113	BUILT
UC-TAD-08	View and export the audit trail	Tenant Administrator	BR-701, BR-705, BR-716	BUILT
UC-TAD-09	Invite, update and remove a user	Tenant Administrator	BR-108	BUILT
UC-PAD-01	Onboard a tenant	Platform Administrator	BR-101, BR-103	BUILT
UC-PAD-01b	Self-service sandbox signup	Prospective Bank (unauthenticated)	BR-109	BUILT
UC-PAD-02	Invite a tenant's first user	Platform Administrator	BR-108	BUILT
UC-PAD-03	Suspend / resume / offboard	Platform Administrator	BR-107	BUILT
UC-PAD-03b	Promote a sandbox to production	Platform Administrator	BR-109	BUILT
UC-PAD-04	Monitor tenant health, fleet-wide	Platform Administrator	BR-208, BR-902, BR-905	BUILT

51 use cases; 50 built, 1 partial, none pending outright — every use case specified here has at least a working path today. UC-PO-02 stays Partial because BR-504/BR-505 (binding the FMR/STR artefact to FIU-IND's prescribed submission format) are themselves Partial, pending OD-04's format choice; the use case's core function — generating and filing the return — is built, and the gap is named in its own detail box rather than in this table's status column. UC-MDL-04 (BR-807/808/AD-14) is Built and has now been exercised against a real model — AI/ML roadmap Phase 2 (transaction velocity/anomaly detection, VEL-04) genuinely scores traffic once a version clears the gate ([§23](#)). Phases 3 and 4 ([AI/ML roadmap](#), OD-06) still have no live scoring.

21. Non-functional requirements

Carried from BRD v1.9 §14, with the one figure this session's work changed: detection latency at single-worker scale is now measured, not merely targeted.

ID	ATTRIBUTE	TARGET	STATUS
NFR-01	Detection latency	Under 5 seconds from receipt to alert at peak	MEASURED AT SINGLE-WORKER SCALE — p99 2.65 s at 200 tps per worker (HLD §11). Multi-worker capacity at a tenant's contracted peak is UNVALIDATED (BR-909)
NFR-02	Ingestion throughput	Sustained peak TPS per tenant, contracted individually	UNVALIDATED

ID	ATTRIBUTE	TARGET	STATUS
NFR-03	Dashboard response	95th percentile under 3 seconds on 12 months of data	UNVALIDATED
NFR-04	Availability	99.5% monthly for the console; 99.9% for ingestion	DESIGN SUPPORTS
NFR-05	Recovery	RPO 15 minutes, RTO 4 hours	PENDING
NFR-06	Data residency	All data in Indian regions (REG-07)	DEPLOYMENT-DEPENDENT
NFR-07	Retention	Fraud records for the statutory period; operational data minimised (REG-05)	BUILT — RETENTION FLOORS AND AUTOMATED PURGE (BR-713)
NFR-08	Auditability	Every figure reproducible as at any past date, against the config then in force	BUILT
NFR-09	Accessibility	WCAG 2.1 AA for the console	NOT ASSESSED
NFR-10	Browser support	Current Chrome, Edge, Firefox, Safari; no external CDN dependency (air-gapped deployments)	BUILT

LATENCY BUDGETS BY DECISION PATH

PATH	BUDGET	BASIS
Inline decision — UPI	80 ms	Tenant-configured, per rail
Inline decision — IMPS	150 ms	Tenant-configured, per rail
Inline decision — Card	100 ms	Tenant-configured, per rail
Near-real-time detection	p99 2.65 s, single worker at 200 tps	Measured (BR-309). Multi-worker figure pending (BR-909)
Machine credential token	1800 s expiry (default)	Configurable per credential at issuance
Human session	30 min access token · 4 h idle · 7 days absolute	BR-709

22. Key data objects

The nouns every use case above operates on, briefly — full schemas are HLD §5 territory; this is only enough to read the use cases without cross-referencing constantly.

OBJECT	KEY STATES / FIELDS	OWNING SERVICE
Tenant	provisioning → active ⇄ suspended → offboarded ; also degraded	tenant-service
Service credential	Scope ingest / decide / ingest+decide ; active → revoked ; rotation with overlap	tenant-service
Case	under_review → rfa_flagged → natural_justice → response_evaluation → fraud_declared → fmr_reported → closed_fraud (terminal), or exonerated at two points, reopenable once	analytics-service
Alert	Band matched, observed value, threshold, config version — the rule-evaluation trace	analytics-service
Decision log (Lane A)	Outcome: clean / matched / budget_exceeded / store_unavailable / no_policy / not_screened ; enforced boolean; would_be action	decision-service
Board pack	draft → superseded or issued ; content-hashed, revisioned	analytics-service
Filing	Kind fmr / str ; generated → superseded or acknowledged	analytics-service
Staff accountability examination	open → concluded ; blocks case closure while open	analytics-service
Recovery / LEA referral	Recorded against a closed or declared fraud case	analytics-service

23. Open items & assumptions

What a reader should not take for granted from the rest of this document — findings from writing it, and constraints inherited from the BRD.

FINDINGS FROM SPECIFYING AGAINST THE RUNNING CODE

- **User invitation is now a Tenant Administrator action.** `POST /tenants/{id}/users` , and the update/remove routes beside it, are guarded by `require_capability("can_admin_tenant")` — checked dynamically against the tenant's own role catalogue (BR-113), not `require_role("platform_admin")` . A guard against leaving a tenant with zero admin-capable users (`_sole_admin_guard`) applies to every reassignment and removal. This was previously platform-only; it no longer is. See §15.
- **SSO / IdP configuration now has a console UI.** A Tenant Administrator can create, edit and delete their own OIDC/SAML providers, with role-mapping validated against the tenant's own assignable roles and the client secret write-only. UC-TAD-03 is now marked Built in §20.
- **Self-service tenant onboarding (BR-109) is now built** as its own unauthenticated path (`POST /tenants/self-service` , UC-PAD-01b) rather than as an extension of user invitation — the two were previously conflated in this document. A prospective

bank provisions a fully working sandbox tenant with no platform_admin action of any kind; isolation is enforced by refusing `source="live"` traffic from a sandbox tenant at the ingestion endpoints themselves, not left to self-reporting. Promotion out of sandbox (UC-PAD-03b) remains a deliberate platform_admin action.

- **A tenant's FRM policy — including its PMLA Principal Officer — now has a console and API path too.** `ConfigCreate.kind` validated against `rule|typology|network_map` only, refusing `policy` at the request schema — not merely a missing editor. That is fixed: a tenant admin can create and activate a policy version from the console, including the Principal Officer field mandatory on every STR (see §10 UC-PO-02), still gated by the same board-attestation requirement on activation as before.
- **Branding and machine-credential administration are tenant-scoped, not role-restricted.** The server checks `resolve_tenant_scope` on these endpoints — any role scoped to the tenant may call them — rather than a specific role name. The console only exposes them to Tenant Administrator, so this is a defence-in-depth gap rather than a live exposure, and is noted for completeness rather than urgency.
- **Maker-checker now extends to privileged configuration changes, not only fraud declaration.** Activating a rule, policy or model config version passes through `pending_activation`: a second, different eligible person must confirm before it reaches live decisioning, and the proposer may not also be the confirmer (BR-715, UC-FRM-03). Closes the item previously carried forward as open below.
- **Champion/challenger evaluation, committee approval, and a loadable artifact reference before a model configuration is promoted are now built — and a model now genuinely scores real traffic.** A new `model` config kind may not even be proposed for activation without a recorded evaluation (BR-807), Model Risk Management Committee sign-off (BR-808), and a verified `model_artifact` reference (AI/ML roadmap Phase 2, HLD AD-14) — see UC-MDL-04. Once activated, analytics-service's detection worker loads that artifact and scores VEL-04 in the same batch every other rule scores in (§23). This was previously a governance floor built ahead of any model existing; it no longer is, for Phase 2 specifically — Phases 3 and 4 ([AI/ML roadmap](#), OD-06) still have no live scoring.
- **RBI's Central Fraud Registry (CFR) needed no second filing.** The Directions define CFR as populated automatically from FMR submissions (already built); the bank's own obligation is to *screen* against it. CFR is now a reference-data source alongside sanctions/PEP/negative-list, feeding CPT-02 (BR-509) — honestly unloaded, since RBI grants CFR access as per-user portal credentials rather than a bulk feed a schedule can poll.

CARRIED FORWARD FROM THE BRD

- FMR and STR artefacts are assembled, validated, hashed and retained in the platform's own structured form; binding to RBI's and FIU-IND's own prescribed submission formats is a compliance decision pending OD-04, not engineering work (UC-PO-02).
- Right-to-audit evidence pack, documented disaster recovery with a stated RPO/RTO, and capacity evidence beyond a single worker are all Pending (BR-908, BR-909, BR-910) — see the BRD's own release-gate table for what each blocks.

ASSUMPTIONS THIS DOCUMENT INHERITS FROM THE BRD

- Each tenant can expose transaction data by API or file within minutes of settlement, and federates identity from an existing IdP rather than managing users in the platform long-term.
- Each tenant's board approves its own thresholds; the vendor supplies defaults, never advice — reflected throughout §6–§16 as "board-approved", never as a platform constant.
- Reference data (sanctions, CERSAI, CBS extracts) is licensed or supplied by the tenant, not by the platform.

24. AI/ML roadmap

What each persona actually sees change, phase by phase. Committed scope per the BRD's [AI/ML roadmap](#) (OD-06); no remaining phase has a committed delivery date, and each depends on the one before it landing first. Phase 2 has now landed - see its own heading below for what actually changed, not just what was planned.

PHASE 1 — DEVICE & BEHAVIOURAL BIOMETRICS

No new screen. The Fraud Analyst's evidence drawer (§6, "why this fired") gains new CHN-family reason codes sourced from device-posture and behavioural-biometric features — typing cadence, touch pressure, session/gesture patterns — alongside the device id already shown there. The EWS Signals dashboard's by-family breakdown starts reporting volume under these new CHN sub-rules. Signal capture and matching are not specified here — they are VideoPD's and the Human Fraud Detection Framework's functional domain; this platform consumes their output as a feature, not a capability it implements itself.

PHASE 2 — TRANSACTION VELOCITY & ANOMALY-DETECTION MODELS **BUILT**

No new screen. This is the first phase where the Model Risk / Data Science persona's existing UC-MDL-01...04 (§13) stop being exercised against an empty inventory: a real **model** config version is proposed, evaluated, committee-approved and now also artifact-verified (AD-14) through the same console flow already built, and the Analyst's alerts genuinely carry a model-scored indicator (VEL-04) alongside the rule-scored VEL family. The Fraud Analyst cannot yet tell which alerts came from which — that distinction is Phase 4's job.

PHASE 3 — GNN-BASED FRAUD-RING DETECTION **BUILT**

The Investigator, Account 360 and AML dashboards' existing network-graph view (already rendering the account graph for visual link analysis) is joined by a new alert indicator, **LAY-05**, alongside the existing layering/mule family in the Analyst's and Investigator's evidence drawer, with its own "why this fired" trace like every other alert (BR-805) — a direct answer to the Senior Investigator's "is this one mule, or a ring?" question (§7) instead of an inference from edge density alone. Resolved by [BRD OD-07](#): this runs within one tenant's own graph, no cross-tenant data-sharing decision needed.

One visible difference from every other indicator: LAY-05's score refreshes on whatever schedule an operator runs `scripts/refresh_ring_scores.py` on (per [HLD §16](#)), not per transaction the way VEL-04 (Phase 2) or the rule-based indicators do — a graph model is too expensive to recompute for every batch. An Investigator opening a

very recent case may see LAY-05 absent rather than stale on a brand-new account the last refresh never saw; the `account_ring_score` row's own `computed_at` is available to show when a present score was last produced, not just what it is.

PHASE 3B — FEDERATED LEARNING DEFERRED

Decoupled from Phase 3 by [BRD OD-07](#): aggregating model updates across tenants/banks is not commercially triggered by any engagement in front of it, and no screen is specified here because none is owed until one exists.

PHASE 4 — EXPLAINABLE-AI DASHBOARDS & REGULATOR-READY REPORTING

The Model Risk dashboard gains a per-alert explainability panel distinguishing a rule-scored decision from a model-scored one, and the scheduled board pack (already built, BR-507) gains an explainability appendix for the RBI Inspection persona — the same "prove why this account was flagged" question §14 already asks of the rules engine, extended to cover Phase 2 and 3's models. Not independently specifiable: there is nothing to explain or report on until those phases produce a model to describe.

Read with BRD v1.9 for the numbered business requirements and release gates, and HLD v1.8 for how each use case is actually carried out underneath — the service, the schema, the latency budget. This document sits between the two: it is BRD requirements resolved into who performs them and how, and it is HLD behaviour resolved into who is allowed to trigger it.